

ANALISI DI SICUREZZA DELL'APPLICAZIONE E E-COMMERCE E PIANO DI INTERVENTO

Andrea Di Rocco

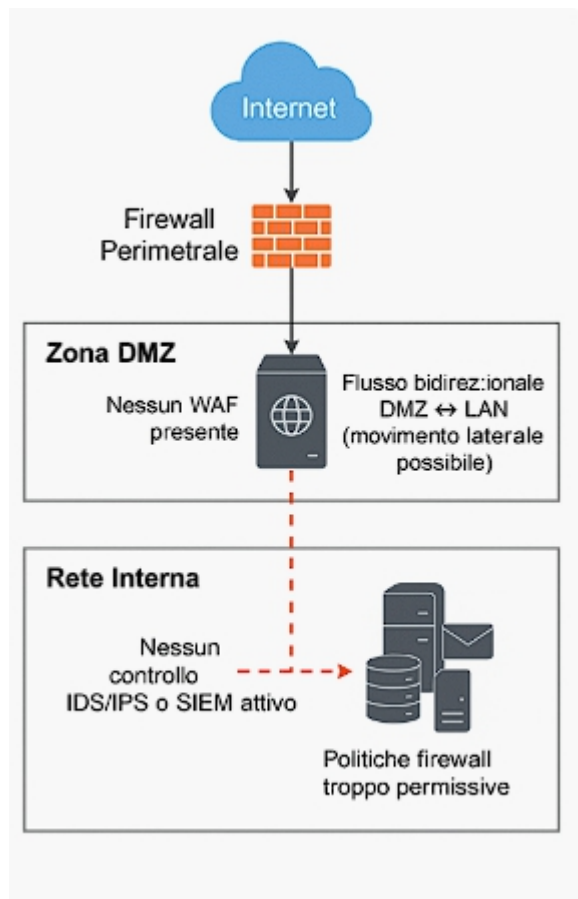
Esame M5 EPICODE 2025



1)Analisi di Sicurezza dell'Applicazione E-commerce e Piano di Intervento

Introduzione e Contesto

In questo elaborato ho affrontato un caso realistico di attacco informatico a un'infrastruttura e-commerce esposta su Internet, analizzando punto per punto i rischi, le vulnerabilità, e le contromisure più efficaci. L'obiettivo è proporre un piano di intervento tecnico e operativo coerente, sostenibile e allineato ai principali standard internazionali di sicurezza.

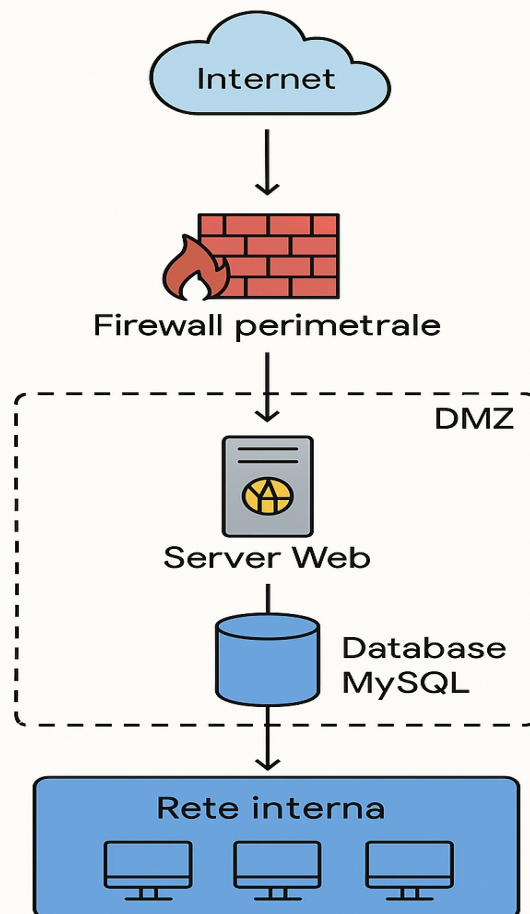


L'azienda in esame gestisce una piattaforma **e-commerce** il cui server web è collocato in una zona DMZ ed esposto ad Internet per consentire agli utenti di effettuare acquisti online.

La **rete interna aziendale** è attualmente accessibile dalla DMZ per via di policy firewall permissive, il che significa che se il server web in DMZ venisse compromesso un attaccante potrebbe potenzialmente propagarsi verso i sistemi interni. In questo rapporto esaminiamo l'infrastruttura attuale, valutiamo le principali minacce e proponiamo un piano completo di **misure preventive** e **strategie di risposta agli incidenti** per migliorare la sicurezza dell'applicazione e garantire la continuità operativa del servizio. L'approccio seguito è **olistico e multilivello**, ponendo enfasi sui principi fondamentali della sicurezza informatica (riservatezza, integrità, disponibilità – la triade **CIA**) e sulla gestione del rischio in ottica business. L'obiettivo ultimo è ridurre i rischi informatici a un livello accettabile proteggendo i dati dei clienti e le transazioni, assicurando al contempo che il sistema rimanga disponibile e affidabile anche di fronte ad attacchi informatici o guasti.

Nel **contesto attuale**, l'architettura di rete prevede: un firewall perimetrale che filtra il traffico Internet verso la **DMZ**, dove risiede il server web di e-commerce;

Architettura iniziale



la DMZ è collegata alla rete interna (LAN aziendale) attraverso regole firewall che, allo stato attuale, consentono varie comunicazioni. I flussi tipici includono: utenti e attaccanti dal web che accedono all'applicazione e-commerce in DMZ, l'applicazione e-commerce che interagisce con sistemi o database nella rete interna, e i client interni che eventualmente accedono al servizio. Questa configurazione offre il necessario accesso pubblico al sito e-commerce, ma presenta **superfici d'attacco e vulnerabilità** significative. In particolare, la possibilità per un host compromesso in DMZ di raggiungere liberamente la LAN interna rappresenta un rischio di **movimento laterale**: idealmente, una DMZ dovrebbe essere strettamente filtrata verso l'interno. Nel nostro scenario, invece, un attaccante che violi il server web potrebbe sfruttare la connettività aperta per attaccare database o altri asset critici all'interno. Inoltre, l'applicazione web stessa, essendo esposta su Internet, è bersaglio potenziale di attacchi applicativi (es. **SQL Injection** e **Cross-Site Scripting**) e di attacchi volumetrici come i **Distributed Denial of Service (DDoS)**. La combinazione di questi fattori rende necessario un intervento mirato sia sul piano preventivo (per ridurre le vulnerabilità e l'esposizione) sia sul piano reattivo (per rispondere efficacemente a incidenti come malware e attacchi in corso).

In sintesi, l'obiettivo di questa relazione è definire un piano di sicurezza completo per l'ecosistema e-commerce, **allineato alle best practice e standard internazionali**. Verranno introdotte soluzioni tecniche (es. firewall applicativi, segmentazione di rete), misure organizzative (es. procedure di incident response, policy di backup) e riferimenti a standard come NIST CSF e ISO 27001 per dimostrare che l'approccio proposto è conforme alle linee guida riconosciute. Inizieremo con un'analisi dell'infrastruttura e delle minacce, per poi dettagliare le misure preventive

implementabili e infine illustrare il piano di risposta ad un incidente informatico già verificatosi (malware sul server web), includendo considerazioni di **continuità operativa** e valutazioni di **impatto sul business**. Tale impostazione sistematica – coprendo **Identificazione, Protezione, Rilevamento, Risposta e Ripristino** (i cinque domini del framework NIST CSF) – garantirà una copertura completa delle esigenze di sicurezza.

2) Analisi dell'Infrastruttura Attuale

Architettura di rete e componenti: L'infrastruttura attuale dell'e-commerce è composta dai seguenti elementi chiave:

- **Zona DMZ (Demilitarized Zone):** una subnet perimetrale isolata dalla rete interna tramite firewall, in cui risiede l'**applicazione web di e-commerce**. Questa è la parte esposta a Internet, accessibile dagli utenti esterni tramite il firewall perimetrale. La DMZ funge da zona cuscinetto: in teoria dovrebbe limitare l'accesso dall'esterno e contenere eventuali compromissioni senza impattare direttamente la LAN interna. Attualmente però la DMZ include solo il server web e non ulteriori componenti di sicurezza avanzati.
- **Firewall Perimetrale:** un firewall di rete che regola il traffico tra Internet, la DMZ e la rete interna. Probabilmente è configurato per permettere il traffico HTTP/HTTPS in ingresso verso il server e-commerce nella DMZ e consentire alcune comunicazioni dal server DMZ verso l'interno (ad esempio per interrogare un database o servizi interni). Tuttavia, sembra che le policy attuali siano piuttosto aperte riguardo al traffico DMZ->LAN, creando un **punto debole** importante.
- **Rete Interna (LAN aziendale):** ospita i sistemi core dell'azienda (es. database transazionale dell'e-commerce, server gestionali, server di posta, ecc.) e gli endpoint degli utenti interni. Questa rete dovrebbe essere ad **alto livello di fiducia** e non direttamente esposta, ma la connettività dalla DMZ significa che il suo perimetro difensivo dipende fortemente dalla robustezza del firewall e dalla sicurezza del server DMZ. Se un attaccante ottiene accesso al server in DMZ, la rete interna può essere raggiunta, permettendo attacchi ulteriori ai sistemi critici (ad es. esfiltrazione di dati dal database clienti).
- **Componenti di sicurezza attuali:** dal testo della traccia non emergono riferimenti a soluzioni di sicurezza specifiche oltre al firewall perimetrale. Non si menzionano ad esempio **WAF, IDS/IPS, SIEM** o altri strumenti. Questo suggerisce che l'architettura in essere è minima e focalizzata sulla funzionalità, mancante di controlli avanzati di sicurezza. Ad esempio, non è presente al momento un Web Application Firewall che ispezioni il traffico HTTP applicativo né segmentazioni ulteriori oltre alla separazione DMZ/LAN.

Valutazione delle vulnerabilità attuali: Dall'analisi della configurazione esistente emergono alcune criticità:

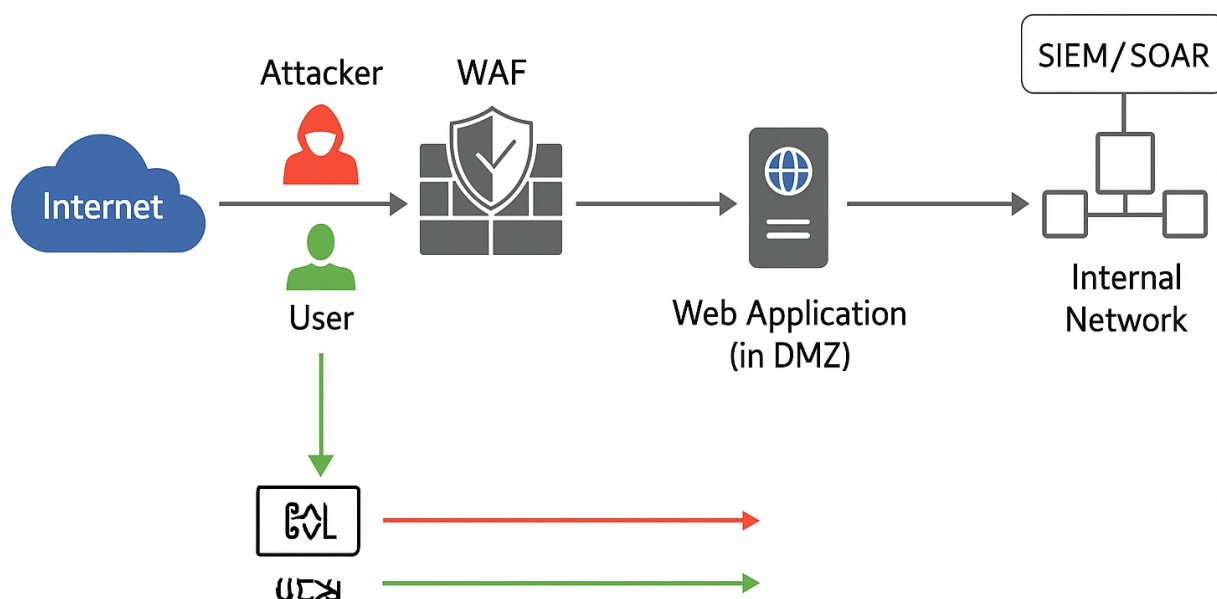
- **La mancanza di segmentazione interna robusta:** come detto, la DMZ non è sufficientemente isolata. Un firewall è presente ma le sue regole permettono al server DMZ di comunicare con l'interno quasi liberamente (es. potrebbe accedere al database interno su più porte, o raggiungere altri host). Ciò contravviene al principio di "zone di fiducia" differenziate. In una buona pratica, se un server DMZ viene compromesso, non dovrebbe poter *liberamente* "muoversi" nella LAN interna. Questa lacuna di segmentazione aumenta il rischio che un singolo punto di fallo (il server web) dia accesso a tutta la rete aziendale.
- **Server web come single point of failure:** attualmente vi è un unico server applicativo in DMZ. Se tale server subisce un guasto o un attacco (es. viene saturato da DDoS o infettato da malware), il servizio e-commerce diventa indisponibile. Non sono indicate misure di ridondanza o failover (come cluster di server web o server di backup pronti a subentrare). Ciò incide negativamente sulla **Disponibilità** – uno dei pilastri della triade CIA – perché non

c'è tolleranza agli errori o agli attacchi DoS.

- **Assenza di specifici controlli applicativi:** il server web e-commerce è esposto a attacchi applicativi sofisticati (injection, XSS, ecc.) e non c'è menzione di contromisure dedicate come un **Web Application Firewall (WAF)** o meccanismi di filtraggio a livello applicativo. Questo significa che eventuali input malevoli potrebbero raggiungere direttamente l'applicazione. Se quest'ultima contiene vulnerabilità (es. query SQL non filtrate correttamente), l'attaccante potrebbe riuscire a sfruttarle.
- **Mancanza di monitoraggio centralizzato:** non risultano implementati sistemi di **logging centralizzato e correlazione eventi (SIEM)**, né sistemi di **Intrusion Detection/Prevention (IDS/IPS)**. Ciò implica una scarsa visibilità su ciò che accade nella rete: un attacco potrebbe passare inosservato finché non causa danni evidenti. Senza un monitoraggio continuo, si rischia di rilevare un'intrusione soltanto a compromissione avvenuta.
- **Procedure e preparazione:** non abbiamo dettagli sulle procedure di sicurezza aziendali, ma dal contesto si evince che non c'è un piano strutturato di incident response già applicato (lo stiamo definendo ora). Verosimilmente manca formazione specifica del personale IT su come reagire ad attacchi, e non sono definite policy formali (es. politica di hardening, aggiornamento, backup e ripristino) oltre a quelle implicite. Questo aspetto organizzativo è importante: un'infrastruttura tecnica robusta deve essere accompagnata da processi e competenze adeguate.

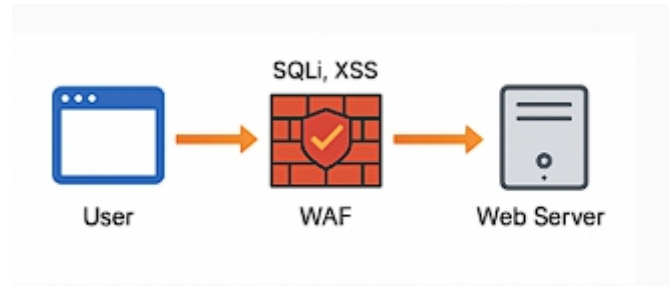
In sintesi, l'infrastruttura attuale garantisce la funzionalità minima del servizio e-commerce ma presenta **significativi margini di miglioramento in termini di sicurezza**. La rete è organizzata su due macro-segmenti (DMZ e Interna) ma l'isolamento è insufficiente; la protezione applicativa e il monitoraggio mancano; la tolleranza ai guasti/attacchi è bassa. Nel seguito del report, partendo da questa analisi, delineremo le principali **minacce** a cui il sistema è esposto e quindi proporremo un insieme articolato di contromisure preventive per mitigare tali rischi, prima di affrontare la strategia di risposta ad un incidente specifico (malware sul server web) già manifestatosi.

Preventive Actions Against SQLi and XSS

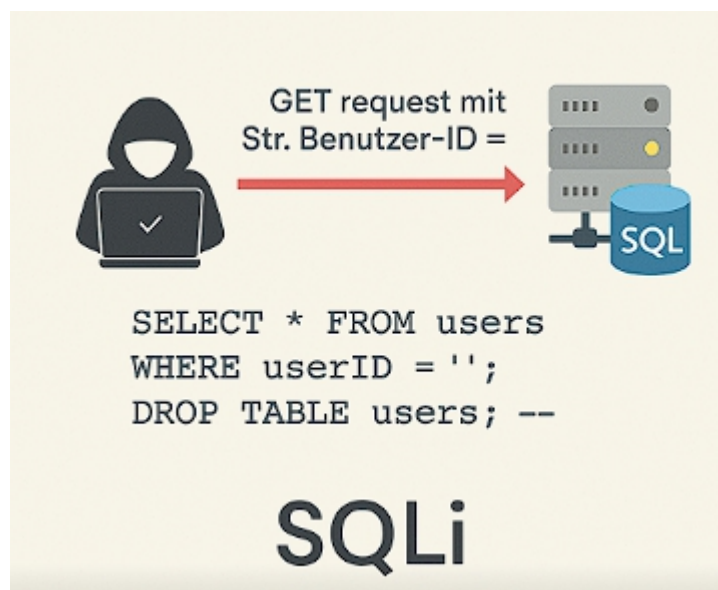


3)Valutazione delle Principali Minacce

In base al contesto e alla configurazione sopra descritta, possiamo identificare diverse minacce rilevanti per l'applicazione e-commerce e l'infrastruttura associata. Di seguito presentiamo le categorie di attacco più significative, il possibile **attore di minaccia** e l'**impatto atteso** in termini di riservatezza, integrità e disponibilità dei sistemi:



- **Attacchi applicativi (SQL Injection, XSS)** – *Attore:* un utente malintenzionato esterno (hacker) che visita il sito e-commerce cercando vulnerabilità nell'applicazione web.
Tecnica: invio di input malevoli attraverso form o parametri URL, per indurre l'applicazione a eseguire comandi non previsti. Ad esempio, un attacco **SQL Injection (SQLi)** consiste nell'inserire nella richiesta HTTP stringhe che “iniettano” comandi SQL nelle query al database, compromettendo potenzialmente l'integrità dei dati o esfiltrando informazioni sensibili. Un attacco **Cross-Site Scripting (XSS)** consiste nell'inserire script malevolo (es. JavaScript) in input che verrà poi restituito ad altri utenti, consentendo di rubare cookie di sessione o impersonare altri utenti. *Impatto:* questi attacchi minacciano principalmente la **confidenzialità** dei dati (esfiltrando dati utenti tramite SQLi o rubando sessioni con XSS) e l'**integrità** (modifica o cancellazione di dati via SQLi). In alcuni casi possono anche colpire la **disponibilità** (una SQLi potrebbe cancellare o bloccare tabelle, un XSS può diffondere malware ai visitatori). Dato che l'e-commerce tratta probabilmente dati personali e transazioni, il rischio è elevato: violazioni di dati potrebbero comportare danni economici (frode, multe GDPR) e reputazionali notevoli.

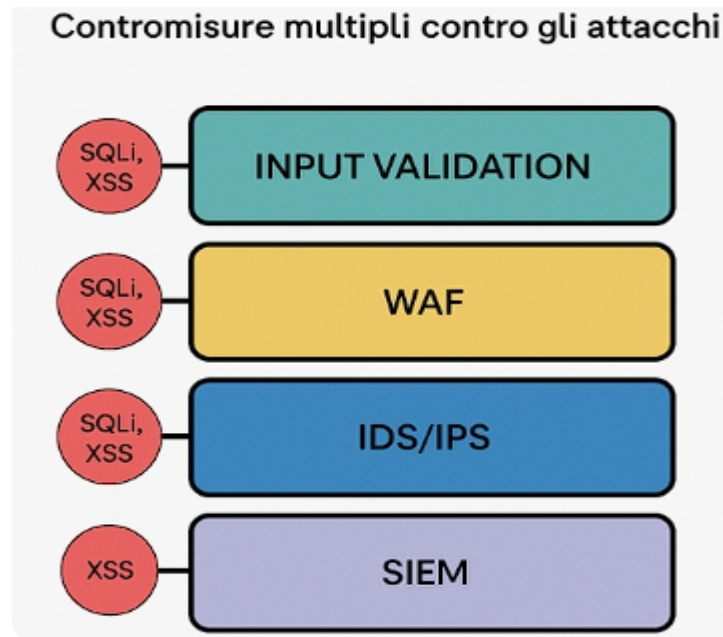


- **Attacchi Distributed Denial of Service (DDoS)** – *Attore:* un aggressore esterno (singolo o gruppo, potenzialmente un network di bot) che vuole rendere indisponibile il servizio.
Tecnica: un attacco DDoS consiste nel generare un volume enorme di traffico verso il server

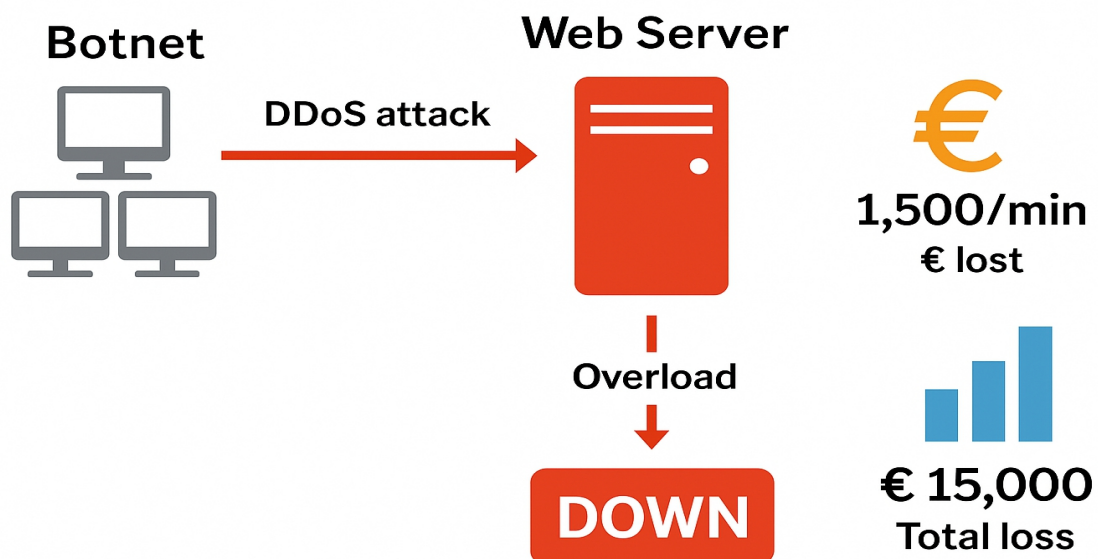
o nel consumare risorse applicative tramite richieste massive, saturando la banda o le capacità di calcolo fino a impedire agli utenti legittimi di accedere al sito. Questo può essere fatto tramite una botnet di migliaia di dispositivi compromessi inviati a bombardare la piattaforma. *Impatto:* la **Disponibilità** del servizio viene colpita in pieno. Nel nostro scenario, la traccia indica esplicitamente un caso: un attacco DDoS esterno rende l'app non raggiungibile per 10 minuti. Ciò provoca un danno economico misurabile – dato che gli utenti in media spendono 1.500 € al minuto, 10 minuti di downtime significano **15.000 € di mancato guadagno** (impatto diretto sul business). Va sottolineato che questo è un caso singolo; attacchi DDoS più prolungati o frequenti potrebbero portare perdite molto maggiori. Ad esempio, se attacchi del genere avvenissero quotidianamente, il costo annuale sarebbe insostenibile (~5,5 milioni di euro, come vedremo nelle conclusioni). Anche se non distruttivo per i dati, il DDoS mina la fiducia dei clienti (che troverebbero il sito spesso offline) e può essere usato come diversivo per altri attacchi. A livello di probabilità, i DDoS sono attacchi in crescita: si stima che quasi 9 milioni di attacchi DDoS siano stati lanciati nell'ultimo anno contro servizi online essenziali, inclusi molte piattaforme.

Questo trend rende la minaccia molto concreta.

- **Malware e compromissione persistente** – *Attore:* può essere sia esterno (un hacker che sfrutta vulnerabilità del server per installare malware) sia interno (un dipendente infetto involontariamente, anche se nel nostro caso l'infezione riguarda il server DMZ). La traccia prospetta uno scenario specifico: *“l'applicazione Web viene infettata da un malware”*. *Tecnica:* il malware potrebbe essere stato piazzato sul server web sfruttando magari un exploit (es. un'RCE su una vulnerabilità non patchata) oppure tramite un file malevolo caricato. Una volta attivo, il malware potrebbe consentire all'attaccante accesso remoto continuo (backdoor) e tentare di propagarsi ad altri sistemi. *Impatto:* in primis l'infezione di un server DMZ compromette la **integrità** e **confidenzialità** di quel sistema (l'attaccante potrebbe sottrarre dati presenti sul server, es. file di configurazione con credenziali, e alterarne il funzionamento). Ma la priorità dichiarata dall'azienda è evitare che si **propaghi nella rete interna**, poiché se il malware contagiassero anche i server interni i danni sarebbero maggiori: perdita di dati sensibili, possibile **data breach** su larga scala, blocco di sistemi core (es. ransomware). Inoltre, la presenza di un intruso persistente rappresenta un rischio continuo finché non viene eliminato. In questo scenario l'azienda paradossalmente afferma di non essere interessata a rimuovere subito l'accesso dell'attaccante sulla macchina infetta – ciò suggerisce una scelta strategica di *containment* controllato (lasciare l'attaccante connesso ma isolato, per poterlo monitorare). Discuteremo questa strategia nella sezione di risposta agli incidenti. In ogni caso, un malware avanzato potrebbe agire silenziosamente (es. trojan che ruba dati) o in modo manifesto (es. crypto-ransomware). La **Disponibilità** del servizio e-commerce potrebbe essere impattata (server compromesso spesso significa servizio offline per bonifica), e la confidenzialità dei dati pure (esfiltrazione). Senza contromisure adeguate un attacco del genere può passare inosservato a lungo, specie se manca un monitoraggio dei log (che potrebbe invece rilevare comportamenti anomali come contatti a server esterni noti malevoli).
- **Minacce interne e altre** – Sebbene il focus primario sia sulle minacce esterne, vale la pena menzionare brevemente anche altri rischi: un **insider malintenzionato** (ad esempio un amministratore di sistema infedele) potrebbe abusare dei propri privilegi, anche se mitigato da controlli di accesso; oppure **errori configurazione** (es. firewall mal configurato, credenziali di default non cambiate) possono essere considerati vulnerabilità interne che un attaccante sfrutta facilmente. Inoltre, essendo un servizio e-commerce, bisogna considerare minacce come **frodi transazionali** o attacchi alla fiducia (es. phishing ai clienti attraverso l'app stessa), ma queste esulano dallo scopo tecnico di questa relazione.



Per ognuna delle minacce elencate, valuteremo contromisure specifiche nella prossima sezione. Prima di procedere, è utile formalizzare brevemente il rischio di business associato: la **Business Impact Analysis (BIA)** per l'e-commerce evidenzia che un downtime di 10 minuti costa circa 15k € di mancati ricavi (come calcolato sopra); proiettando questo dato, un'ora di fermo costerebbe 90k € e un'intera giornata quasi 2,2 milioni. Ciò aiuta a motivare investimenti in misure di prevenzione e resilienza: ad esempio, se un giorno di interruzione costa ~100k €, spendere magari 50k € all'anno in soluzioni di protezione è ampiamente giustificato. Questo principio costo/beneficio verrà ripreso nelle conclusioni, dove mostreremo come le misure proposte – pur avendo costi – risultino economicamente sensate rispetto ai danni potenziali evitati.



4) Misure Preventive Proposte

Alla luce delle minacce identificate, presentiamo ora un insieme di **misure preventive** da implementare per rafforzare la sicurezza dell'applicazione e dell'infrastruttura. Adotteremo un approccio di **difesa in profondità**, implementando controlli su vari livelli: applicativo, di rete, e organizzativo. Ciascuna misura sarà descritta evidenziandone lo scopo, la modalità di implementazione e come contribuisce a mitigare specifici rischi. L'insieme di queste contromisure mira a prevenire o ridurre significativamente la probabilità di incidenti (o a limitarne l'impatto qualora avvengano).

1. Controlli di Sicurezza a Livello Applicativo (Web App):

- **Secure Coding e Validazione Input:** Prima linea di difesa contro attacchi come SQLi e XSS è assicurare che l'applicazione sia sviluppata seguendo pratiche di **secure coding**. Tutti gli input forniti dagli utenti devono essere convalidati e sanificati lato server (e preferibilmente anche lato client) per rimuovere o neutralizzare caratteri pericolosi. Ciò include utilizzare query parametrizzate o ORM per qualunque interazione col database (evitando di concatenare stringhe SQL), e fare escaping/encoding dei dati visualizzati in pagina per prevenire l'esecuzione di script indesiderati nel browser dell'utente (mitigazione XSS). È consigliabile adottare un approccio **whitelist** per gli input (accettare solo ciò che aderisce al formato atteso, es. numeri in un campo quantità, lettere in un nome, ecc.) e implementare filtri lato server robusti. Ad esempio, ogni campo testo potrebbe avere una lunghezza massima e vietare caratteri speciali se non necessari; ogni input utilizzato in query SQL dovrebbe passare per funzioni di **escape** o meglio per parametri bind dell'SQL driver. Inoltre, a livello di sviluppo, si dovrebbe integrare un processo di **Secure Development Lifecycle (SDLC)**, con revisioni del codice focalizzate sulla sicurezza e test specifici per individuare e correggere vulnerabilità applicative prima del deploy. In sintesi, il codice dell'applicazione va reso il più robusto possibile: queste misure preventive **non eliminano la necessità di protezioni esterne**, ma assicurano che il sistema non sia “di vetro” qualora un input malevolo riesca a passare. È importante sottolineare che il secure coding deve diventare parte integrante delle policy IT aziendali, con **formazione** agli sviluppatori sulle principali vulnerabilità OWASP e come evitarle.
- **Web Application Firewall (WAF):** Inseriremo un WAF dedicato a proteggere l'applicazione web da attacchi mirati alle sue vulnerabilità note e sconosciute. Il WAF agirà come un filtro avanzato per tutto il traffico HTTP/HTTPS diretto all'e-commerce. Posizionato all'ingresso della DMZ (tra Internet e il server web), **analizza in tempo reale le richieste** in arrivo e identifica pattern malevoli noti (grazie a firme, regole e analisi del comportamento) bloccandoli **prima** che raggiungano il server applicativo. Il WAF funge quindi da **barriera esterna dedicata alle minacce applicative**, complementando il firewall tradizionale che lavora a livello di IP e porte. Un grande vantaggio è la possibilità di aggiornare rapidamente il WAF con nuove regole non appena emergono vulnerabilità 0-day o nuovi exploit, così da proteggere l'applicazione anche nell'intervallo in cui gli sviluppatori preparano una patch di codice. In pratica il WAF può fornire una sorta di “**patch virtuale**” temporanea, riducendo drasticamente il rischio di successo di attacchi web comuni. Va notato però che **il WAF non sostituisce il codice sicuro**: si tratta di difesa in più ma si assume che l'applicazione venga comunque corretta a monte. Per implementazione, si può optare per soluzioni open-source come **ModSecurity** (WAF software integrabile con server Apache/Nginx) o soluzioni enterprise hardware/cloud (es. F5 BIG-IP ASM, Cloudflare WAF). *Esempio:* ModSecurity è un noto WAF open-source mantenuto da OWASP, spesso usato con le Core Rule Set OWASP per intercettare attacchi comuni. Soluzioni cloud come Cloudflare o Akamai possono filtrare il traffico prima offrono regole gestite da esperti (utile in contesto di e-commerce online). Un WAF ben configurato, con regole aggiornate, potrà bloccare non solo SQLi/XSS ma anche altre minacce web (inclusi **bot maligni**, attacchi di

session cookie, exploit di vulnerabilità note nelle piattaforme usate, ecc.). Inoltre molti WAF forniscono log dettagliati e report utili a capire la natura degli attacchi bloccati, informazioni preziose da integrare nel monitoraggio generale di sicurezza.

- **Controlli aggiuntivi a livello applicativo:** Oltre a WAF e secure coding, vanno citati ulteriori controlli preventivi: l'implementazione di una robusta **autenticazione** e gestione delle sessioni (assicurarsi che password utente siano conservate con hash forte, usare token anti-CSRF, scadenza sessioni inattive, etc.), l'abilitazione di **Content Security Policy** sul sito per mitigare XSS (consentendo script solo da fonti fidate), e la cifratura del traffico (**HTTPS** ovunque) per proteggere i dati in transito ed evitare intercettazioni/manipolazioni (quest'ultima tutela la confidenzialità e integrità dei dati durante il viaggio). Anche se l'attacco non riguarda strettamente la rete (nel caso SQLi/XSS l'attaccante è già connesso via HTTP), queste misure completano un profilo di applicazione sicura. Infine, raccomandiamo test di sicurezza applicativa periodici: ad esempio **penetration test** e **code review** eseguiti da team esterni o dal proprio SOC, per scoprire eventuali nuove vulnerabilità.

2. Controlli di Sicurezza a Livello di Rete e Infrastruttura:

- **Segmentazione di Rete e Firewall Interni:** È prioritario migliorare la segmentazione esistente. In particolare, **rafforzare l'isolamento tra DMZ e rete interna**. Propongo di rivedere le regole del firewall perimetrale (o introdurre un secondo firewall dedicato tra DMZ e LAN, in un modello a doppia DMZ) in modo che il server web DMZ **possa comunicare solo con ciò che è strettamente necessario nella LAN**. Ad esempio, se il server e-commerce ha bisogno di interrogare un database interno, si autorizzerà esclusivamente il traffico dal server DMZ verso l'IP del database sulla porta specifica (es. 3306 per MySQL) e nulla più. Tutti gli altri percorsi DMZ->Interno verranno *negati* per default. Idealmente, potremmo introdurre un **firewall interno** aggiuntivo (un firewall di seconda linea) che filtri qualsiasi traffico che eventualmente riesca a passare la prima barriera. Inoltre, se possibile, sarebbe consigliabile collocare il **database dell'e-commerce** in una subnet separata, anch'essa opportunamente filtrata (un'ulteriore DMZ interna dedicata ai dati). Così anche se il server web viene compromesso, l'attaccante non troverà una LAN "flat" ma incontrerà un altro ostacolo prima di raggiungere il DB o altri server interni. Questa difesa per zone può essere implementata con VLAN separate e ACL restrittive su switch/router interni, o con firewall/NGFW segmentati. La **segmentazione** limita enormemente il **movimento laterale**, riducendo l'impatto di una violazione: un intruso nella DMZ avrà difficoltà a vedere e colpire asset interni sensibili senza ulteriori exploit. Come parte di questa misura, rientra anche la creazione di una **rete di quarantena** ovvero predisporre un segmento isolato dove poter collocare eventuali host compromessi per analizzarli o contenerli senza rischi per la LAN operativa. Questo segmento di quarantena può essere un'altra DMZ ("DMZ2") non connessa alla LAN, usata temporaneamente durante gli incidenti – alcuni disegni di architettura la includono come rete separata collegata solo a Internet, proprio per gestire host infetti in modo controllato.
- **Firewall Perimetrali e Next-Generation Firewall (NGFW):** Oltre a rivedere le policy, si può valutare l'aggiornamento del firewall perimetrale a tecnologie di **nuova generazione**. Un NGFW aggiunge funzioni di **deep packet inspection** e può riconoscere applicazioni e intrusioni note nel traffico, combinando le funzionalità di firewall classico e IDS/IPS. Ad esempio, un NGFW potrebbe individuare e bloccare automaticamente uno specifico exploit o malware nel traffico HTTP o rilevare comportamenti anomali (es. un flusso di dati insolitamente grande, o un protocollo proibito). Questo arricchisce la difesa di rete oltre al semplice blocco di porte. Nel nostro scenario, un NGFW potrebbe riconoscere anche un attacco **DDoS a livello di protocollo** (es. un SYN flood) e mitigarlo in tempo reale limitando il rate o attivando specifiche protezioni anti-DoS. In ogni caso, la regola d'oro è

default deny: tutto ciò che non è espressamente permesso è bloccato. Quindi il firewall perimetrale va configurato per bloccare tutte le porte e servizi non necessari sia in ingresso che in uscita (ad esempio, il server web DMZ non dovrebbe avviare connessioni uscita se non per comunicare con il DB, quindi eventuali connessioni anomale – come un malware che tenta di chiamare il suo server C2 – sarebbero bloccate e loggate).

- **Protezione contro Attacchi DDoS:** Per la minaccia di Denial of Service servono misure specifiche orientate alla disponibilità. Una prima linea d'azione è utilizzare servizi di **DDoS Protection/Mitigation** spesso offerti da provider terzi o integrati nei servizi cloud. Si può ad esempio instradare il traffico utenti attraverso una **Content Delivery Network (CDN)** con funzionalità anti-DDoS (come Cloudflare, Akamai, AWS CloudFront/Shieldsec.). Questi servizi distribuiscono il carico su rete globale e filtrano i picchi di traffico malevolo lontano dall'infrastruttura originaria. In pratica, il DNS del sito e-commerce potrebbe puntare a Cloudflare, che funge da proxy: il traffico legittimo viene inoltrato al server, quello sospetto (es. un enorme numero di richieste da bot) viene riconosciuto e bloccato a monte.

Un'altra tecnica è abilitare **meccanismi di rate limiting e throttling** sul web server o sul WAF, in modo da limitare il numero di richieste per IP o per sessione e prevenire abusi (es. se un singolo client supera un certo numero di richieste al secondo, viene temporaneamente bloccato). Questo può fermare i DoS a livello applicativo. Inoltre, l'azienda dovrebbe considerare di **aumentare la banda Internet e la capacità** dei server (per assorbire meglio eventuali picchi – tuttavia questa è solo una misura palliativa, poiché attacchi DDoS su larga scala satureranno qualunque link se non filtrati. *Considerazione costi:* soluzioni anti-DDoS cloud hanno costi variabili; un servizio enterprise può costare nell'ordine di alcune centinaia di euro al mese. Ad esempio, uno studente ha stimato 1000 €/mese per un servizio CDN con protezione DDoS professionale, cifra sostenibile se confrontata con centinaia di migliaia di euro di possibili perdite annue da downtime. Questo trade-off costi/benefici rende chiaro che investire in prevenzione DDoS è giustificato dal business . Da un punto di vista implementativo, configurare una CDN/anti-DDoS richiede di reindirizzare il traffico e impostare le regole di filtraggio adeguate (ad esempio filtri geolocalizzati se attacchi provengono da regioni dove non ci sono clienti, challenge CAPTCHA per richieste sospette, ecc.). L'efficacia di queste misure è alta: come raccomandato da varie linee guida, un WAF unito a CDN è tra le migliori pratiche per mitigare attacchi DDoS applicativi e volumetrici.

- **Sistemi di Rilevamento Intrusioni (IDS/IPS):** Parallelamente alle difese preventive, è utile inserire un componente di **Network IDS/IPS** a monitorare il traffico di rete e identificare eventuali attacchi in corso che bypassino le prime difese. Un IDS di rete (Intrusion Detection System) può essere collegato a uno **span port** sullo switch della DMZ o integrato nel firewall stesso, e analizzerà tutto il traffico alla ricerca di pattern noti di attacco o anomalie (per esempio scansioni di porta, exploit noti, traffico comando-controllo di malware). In caso rilevi qualcosa, genererà allarmi; un IPS può anche bloccare direttamente il traffico malevolo. IDS/IPS agiscono quindi da “rete a strascico” per catturare ciò che potrebbe sfuggire a firewall e WAF. Per esempio, se un attaccante usa un toolkit sconosciuto per sfruttare una nuova vulnerabilità, l'IDS potrebbe non avere una firma specifica, ma potrebbe comunque notare un comportamento anomalo e segnalarlo. Esistono ottime soluzioni open-source come **Snort** o **Suricata** che possono essere implementate con costi ridotti, aggiornando regolarmente le signature community. Anche **OSSEC** è una soluzione open-source interessante, soprattutto lato host: OSSEC è un HIDS (Host-based IDS) che esamina log e integrità dei file sugli host per individuare modifiche sospette ed è spesso considerato parte di un ecosistema SIEM open-source. Ad esempio, OSSEC sul server web potrebbe avvisare se un file critico viene modificato (potenziale segno di web defacement o malware) o se comparissero indicatori di attacco nei log di Apache. Integrare IDS/IPS fornisce un livello di **rilevamento precoce**: non previene gli attacchi da solo, ma ci permette di scoprirli e reagire prima che causino troppi danni. Nel nostro caso, l'IDS potrebbe

rilevare, ad esempio, un'attività di scansione del server (precedente a un attacco), tentativi di exploit SQLi (pattern noti nelle richieste HTTP) o comunicazioni anomale dal server DMZ verso IP esterni rari (potrebbe indicare un malware che comunica col suo server di controllo). Questa visibilità è cruciale per attivare subito l'incident response.

- **Hardening dei sistemi e gestione delle patch:** Come misura preventiva di base, tutti i sistemi critici (il server web in primis, ma anche sistemi operativi, database, etc.) devono essere **hardened** e mantenuti aggiornati. Hardening significa configurare ciascun server seguendo best practice di sicurezza: rimuovere servizi non necessari, chiudere porte inutilizzate, impostare password robuste e policy di account (disabilitare utenti di default, disattivare login amministrativi diretti se non indispensabili), applicare il principio del **minimo privilegio** per utenti e processi.

Inoltre, **applicare le patch di sicurezza** non appena disponibili è fondamentale: vulnerabilità note come quella sfruttata da WannaCry erano risolvibili con patch rese disponibili mesi prima. Un processo di **Patch Management** strutturato dovrà essere adottato: monitorare i bollettini di sicurezza dei fornitori, testare le patch in staging e poi deployarle rapidamente in produzione. Ciò riduce la finestra di esposizione a exploit noti. In un contesto e-commerce, patchare sia il sistema operativo sia la piattaforma applicativa è cruciale: molte intrusioni web avvengono sfruttando CVE per le quali esiste già un aggiornamento. Hardening e patching riducono la probabilità di compromissione iniziale (ad esempio, un attaccante che sfrutta credenziali di default fallirebbe se queste sono state rimosse; un exploit RCE nota non funzionerà se la patch è presente). Queste attività dovrebbero essere formalizzate in una **policy di hardening e patch** a livello aziendale, magari aderendo a benchmark noti (es. CIS Benchmarks per hardening).

- **Soluzioni Anti-Malware ed EDR:** Sul server web (e sugli altri sistemi chiave) dovrebbero girare soluzioni antimalware aggiornate. Un antivirus/antimalware server può rilevare payload noti di malware e bloccarli. Ancora meglio, implementare un sistema **EDR (Endpoint Detection & Response)** sulle macchine critiche: l'EDR monitora in tempo reale comportamenti sospetti a livello endpoint (esecuzione di processi anomali, modifiche al registro, connessioni verso host insoliti) e può intervenire bloccando processi malevoli o isolando la macchina dalla rete automaticamente. Nel caso specifico del server e-commerce, un EDR avrebbe potuto forse rilevare la presenza di malware (ad esempio se comincia a cifrare file o scaricare componenti sospetti) e isolare il server prima che il malware si propaghi ulteriormente. Ci sono versioni enterprise (CrowdStrike, CarbonBlack) ma anche open-source limitate (OSSEC ha funzioni di active response). Data la criticità del server DMZ, investire in un agente EDR è consigliabile.

3. Controlli Organizzativi e Procedurali:

- **Policy di Sicurezza e Formazione:** Contestualmente alle misure tecniche, l'azienda deve aggiornare il proprio quadro di **policy interne** in materia di sicurezza. Ad esempio, definire chiaramente una **Web Application Security Policy** che inglobi le regole di secure coding menzionate, una **Password Policy** robusta per tutti gli account (minima lunghezza, complessità, scadenza periodica), una **Network Security Policy** che sancisca la segmentazione e i flussi consentiti, ecc. Particolarmente importante è avere una **policy di Incident Response**: un piano scritto che descriva ruoli, responsabilità e passi da seguire in caso di vari tipi di incidente (es. malware, DDoS, data breach). Questo funge da playbook a cui il team potrà attenersi quando un evento si verifica, riducendo l'improvvisazione e gli errori sotto pressione.

Parallelamente, la **formazione del personale IT** e degli sviluppatori è essenziale: ad esempio, training periodici per i developer sulle vulnerabilità applicative (SQLi, XSS etc.) così che scrivano codice sicuro, e addestramento del team operativo (SOC) per riconoscere

segnali di intrusione e reagire prontamente (interpretare gli alert del SIEM, seguire le procedure di containment).

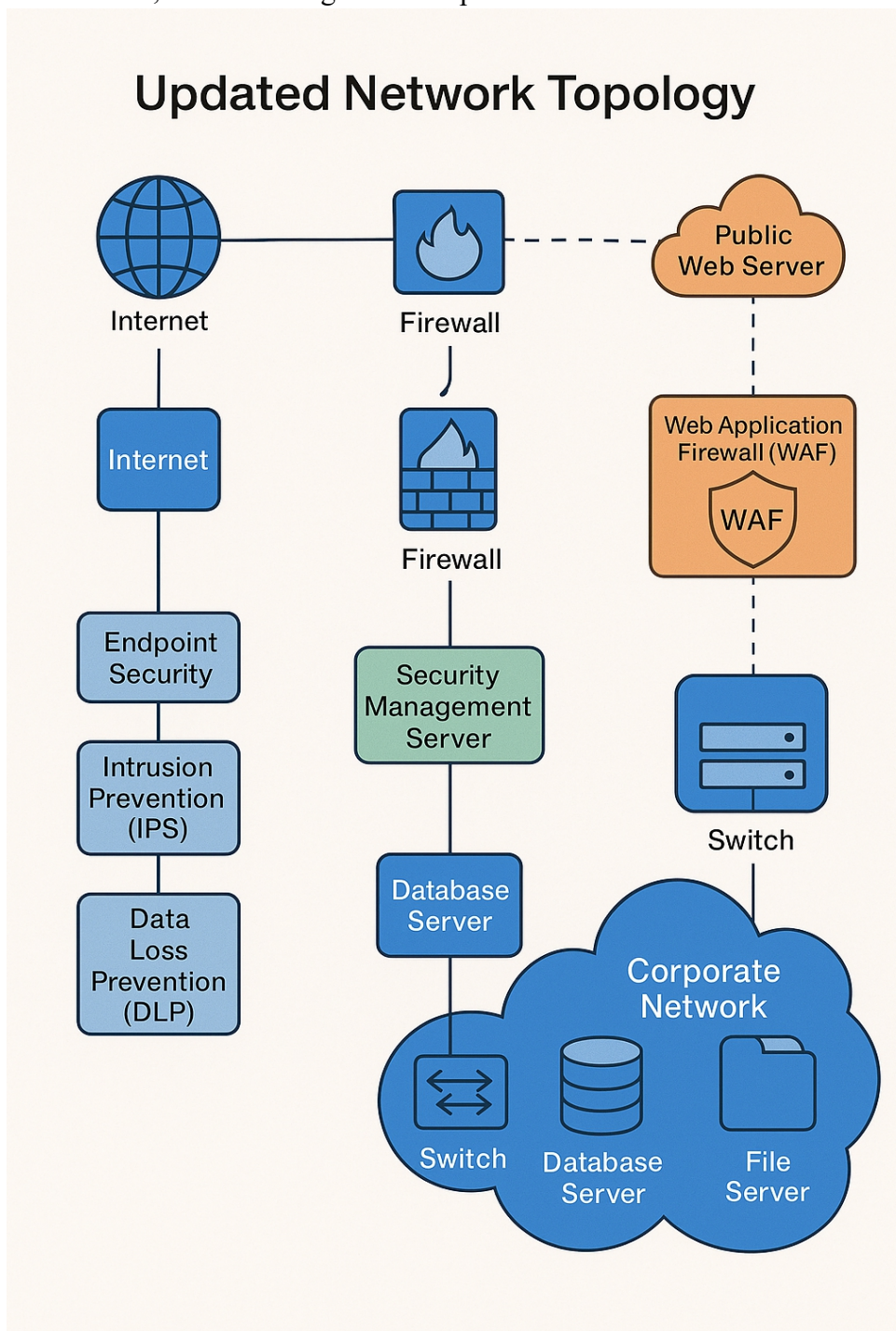
- **Logging centralizzato e SIEM:** Implementare un sistema di **raccolta log centralizzato** è sia una misura tecnica che procedurale: bisogna configurare tutti i dispositivi (server web, firewall, WAF, IDS, server DB, sistemi vari) affinché inviino i loro eventi di log ad una piattaforma centralizzata di analisi (un **SIEM – Security Information and Event Management**).

Un SIEM consente di correlare eventi disparati e individuare pattern di attacco che un singolo log da solo non rivelerebbe. Ad esempio, il SIEM potrebbe correlare un evento del WAF (tentativo di SQLi bloccato) con, subito dopo, un picco di errori di login segnalati dal server (tentativi di brute force) e con traffico anomalo sul firewall: insieme questi eventi indicano un attacco combinato in corso. Con una console SIEM, gli analisti possono avere **visibilità unificata**. Inoltre, il SIEM può generare **allarmi in tempo reale** al superamento di certe soglie. Molti SIEM moderni integrano funzionalità SOAR (automation) che possono, ad esempio, eseguire automaticamente un certo script di risposta quando scatta un alert (es. isolare un host). Ci sono soluzioni open-source come **OSSIM (AlienVault)** o **Elastic Stack (ELK) + SIEM plugin**, fino a prodotti enterprise come Splunk, QRadar, ArcSight. Considerando budget ed esigenze, si potrebbe iniziare con strumenti open. L'importante è definire **quali log raccogliere** (firewall, eventi WAF, log applicazione, autenticazioni, chiamate di sistema) e tarare bene gli alert per non avere troppi falsi positivi. La presenza di un SIEM nel nostro piano serve anche alla fase di detection: ci aiuterà a **rilevare tempestivamente** tentativi di intrusione o anomalie (ad esempio, sarebbe un SIEM ad allertare se un attacco DDoS è in corso, misurando che il numero di richieste al minuto è schizzato oltre soglia). In ottica procedurale, bisognerà definire chi nel team guarda gli alert e garantire un monitoraggio 24/7 per gli eventi più critici.

- **Backup e Piano di Business Continuity:** Tra le misure preventive lato **disponibilità**, è d'obbligo parlare di **backup dei dati** e predisposizione di un **piano di continuità operativa**. La piattaforma e-commerce sicuramente gestisce database transazionali (ordini, pagamenti, clienti) che sono asset vitali. Occorre implementare una strategia di **backup 3-2-1**: mantenere almeno **3 copie** dei dati (produzione + 2 backup), su almeno **2 supporti diversi**, di cui **1 off-site** in luogo geografico separato. Questo per assicurarsi che un singolo evento non distrugga tutti i dati. I backup devono essere **frequenti** e **testati** periodicamente per verificarne l'integrità. Per la continuità operativa, definire un **Business Continuity Plan (BCP)** con relativo **Disaster Recovery Plan (DRP)**: questo includerà l'analisi già accennata, gli **RTO/RPO** target per i servizi (es. RTO – Recovery Time Objective – di qualche ora al massimo per il sito e-commerce) e le strategie per rispettarli. Strategie possibili: predisporre un **server di backup** dell'applicazione e-commerce pronto a subentrare in caso di guasto del primario. Nel nostro scenario potremmo ad esempio avere un secondo server web in standby nella DMZ, aggiornato in tempo reale o quasi (replica dei dati, sincronizzazione) che possa essere messo online nel giro di minuti se il principale cade. Questo ridurrebbe molto i tempi di ripristino. Un altro livello è considerare un **Hot site** (sito secondario completo attivo in standby, per disastri maggiori) se il budget lo consente. Per un downtime tollerato di soli 10 minuti forse un hot site è addirittura necessario (ma comporta costi alti). Nel definire il piano, includeremo procedure dettagliate di recupero: ad esempio, “in caso di attacco malware su server X, isolare server X, attivare server Y pulito di backup con ultima copia dei dati e reindirizzare il traffico”. Già in questa sezione preventiva stiamo predisponendo l'**infrastruttura di riserva** in modo da non improvvisare durante l'incidente. Nella sezione seguente vedremo come nel caso concreto l'azienda attivi un server pulito di backup per mantenere il servizio. Tutto ciò rientra nella prevenzione (disponibilità) e si allinea allo standard **ISO 22301** sulla continuità operativa. Un BCP adeguato garantirà che anche se succede il peggio (attacco riuscito, server offline), l'azienda può continuare a

operare accettabilmente mentre risolve il problema.

Riassumendo, le misure preventive proposte coprono vari aspetti: **tecnologie** (WAF, NGFW, IDS, anti-DDoS, backup), **configurazione** (hardening, patching, segmentazione) e **processi** (policy, monitoring, training, BCP). Questo approccio integrato assicura che l'azienda non faccia affidamento su un singolo controllo magico, ma abbia più livelli di difesa (**"Defense in Depth"**). Ad esempio, per prevenire SQLi/XSS abbiamo contemporaneamente migliorato il codice (per ridurre vulnerabilità), inserito un WAF (per filtrare exploit), formato gli sviluppatori (per non introdurre bug) e implementato monitoraggio (per accorgerci se qualcosa passa). Analogamente per malware e DDoS: li contrastiamo riducendo la superficie d'attacco (segmentazione), dotandoci di strumenti specifici (EDR, anti-DDoS), e predisponendo reazioni rapide (playbook e backup pronti). In tal modo, anche se un controllo fallisse, altri intervengono a compensare.



5) Piano di Risposta agli Incidenti (Caso: Malware sul Server Web)

Nonostante tutte le misure preventive, dobbiamo essere preparati al caso in cui un incidente si verifichi comunque. Una risposta tempestiva e appropriata può contenere i danni e ripristinare il servizio in tempi minimi, salvando la situazione. Nel nostro scenario, simuliamo un incidente grave: l'applicazione web in DMZ è stata **infettata da un malware**, e l'attaccante ha accesso persistente a quella macchina. La priorità dichiarata dall'azienda è **impedire la propagazione** del malware nella rete interna, mentre non si ha interesse immediato a rimuovere l'accesso dell'attaccante alla macchina infetta (presumibilmente per poterlo monitorare o perché l'asset può essere sacrificato). In altre parole, l'obiettivo primario è **contenere** l'incidente isolando il server compromesso, garantendo al contempo la **continuità del servizio** e magari raccogliendo intelligence sull'attaccante. Esplicitare questo obiettivo è importante: *la priorità è impedire la propagazione del malware mantenendo però l'attaccante connesso per poterlo monitorare*. Ciò orienterà le azioni da intraprendere.

Di seguito articoleremo la risposta secondo le fasi tipiche di un **Incident Response** professionale (seguendo il modello SANS: **Preparazione, Identificazione, Contenimento, Eradicazione, Ripristino, Lessons Learned**), concentrandoci in particolare sul **Containment** dato lo specifico requisito del caso. Alcune di queste azioni sono state già in parte predisposte nelle misure preventive (preparazione), come l'esistenza di un playbook e server di backup; ora descriviamo l'effettiva esecuzione passo-passo:

1. Identificazione e Analisi dell'Incidente: Ipotizziamo che un alert del SIEM o un'anomalia nei log abbia segnalato un comportamento sospetto sul server e-commerce – ad esempio traffico in uscita verso un IP sconosciuto o processi non autorizzati in esecuzione. Il team SOC/CSIRT attiva la procedura: conferma l'incidente (analizzando i log, magari collegandosi in remoto sulla macchina per raccogliere informazioni di base – es. elenco processi, connessioni attive, file recenti) e classifica l'evento come “*malware in host DMZ*”. A questo punto, in linea con il playbook, si convoca l'incident response team (che include personale IT, sicurezza, e se necessario management per decisioni di impatto). Nel nostro scenario diciamo che l'analisi rivela la presenza di un **trojan/backdoor** che sta comunicando con un server degli attaccanti e potrebbe tentare movimenti laterali.

2. Contenimento (Isolamento del server compromesso): Questa è la fase cruciale. Dato che il malware è attivo sul server DMZ ma l'attaccante è ancora connesso, dobbiamo **isolare la macchina** per evitare danni ulteriori, senza staccare completamente la spina (per soddisfare la richiesta di mantenere l'accesso dell'attaccante per ora). Ci sono due approcci possibili per il containment, li chiameremo A e B:

- **Approccio A – Quarantena Totale (Rete di Quarantena dedicata):** consiste nel **spostare fisicamente o logicamente il server infetto in una rete isolata** che ha collegamento solo con Internet ma **nessuna connessione verso la rete interna**. In pratica, il server viene tagliato fuori dalla LAN aziendale ma rimane raggiungibile dall'attaccante dall'esterno. Questo soddisfa sia la condizione di proteggere la LAN (nessuna propagazione possibile) sia di non interrompere la connessione dell'attaccante. L'attaccante probabilmente non si accorge subito di essere confinato, poiché la sua sessione rimane attiva e il server risponde ancora, ma in realtà è stato messo in una **sandbox network** dove non può fare danni. Questo scenario può essere realizzato, ad esempio, modificando rapidamente le VLAN: assegnando al server DMZ una VLAN di quarantena che è autorizzata a uscire su Internet ma non a raggiungere nessun IP interno. Se l'azienda dispone di una seconda DMZ (DMZ2) o di un'infrastruttura SDN flessibile, ciò può essere fatto in pochi minuti. In assenza di ciò, si potrebbe ottenere un effetto simile via firewall, creando regole che blocchino *tutto* il traffico dal server verso l'interno. Il risultato è che il server “crede” di essere ancora online ma

qualsiasi tentativo del malware di scansionare o attaccare l'interno fallirà. **Pro:** massima sicurezza per la rete interna, possibilità di monitorare l'attaccante in ambiente confinato; **Contro:** richiede un po' di preparazione infrastrutturale (una rete dedicata) e il server infetto in quarantena potrebbe non poter più servire gli utenti legittimi se anche questi risiedono in LAN (ma nel nostro caso gli utenti sono Internet quindi non è un problema).

- **Approccio B – Isolamento via Firewall (contenimento rapido):** se per qualche ragione non fosse attuabile la quarantena su rete separata, si può optare per un isolamento “logico” tramite firewall sulla configurazione esistente. In pratica: aggiungere immediatamente regole firewall molto restrittive che **bloccano ogni comunicazione tra il server DMZ infetto e qualsiasi host interno**. Già predisponendo la segmentazione come proposto nelle preventive, di fatto questo scenario sarebbe già realtà (il server DMZ non dovrebbe avere ampie possibilità di propagazione). Ma in reazione all'incidente possiamo rafforzare ulteriormente: *tutti* i flussi dal server infetto verso la LAN vengono interdetti (anche quelli che normalmente servivano l'applicazione, come la connessione al DB – questo però significa che l'applicazione perderà funzionalità, ad esempio non potrà interrogare il DB finché è isolata). L'accesso Internet invece rimane aperto, così l'attaccante continua a poter interagire col server. Rispetto ad A, qui il server resta nella DMZ originale ma è come se fosse circondato da “muri invisibili” che gli impediscono di muoversi dall'angolo in cui è. **Pro:** implementazione molto rapida (basta cambiare configurazione firewall), non serve spostare cavi o VLAN; **Contro:** il server infetto rimane nella stessa subnet della produzione, il che è potenzialmente meno sicuro (se l'attaccante ha più di un modo di comunicare potrebbe cercare vie alternative), inoltre come detto l'app e-commerce su quel server, se perde accesso al DB interno, smetterà di essere funzionale.

Nel nostro caso concreto, seguendo la best practice, adotteremo l'**Approccio A (Quarantena)** che offre maggior garanzie. Possiamo farlo grazie alla presenza (che avremo predisposto) di un segmento di quarantena DMZ2. Quindi, non appena scattato l'allarme, il team:

- Cambia la configurazione di rete del server infetto per collegarlo alla DMZ2 isolata (questo può voler dire spostare un cavo su uno switch differente, o se è una VM, cambiare la network nel hypervisor). In alternativa, se ciò richiede troppo tempo fisicamente, applichiamo comunque subito regole firewall per bloccare la LAN e poi procediamo allo spostamento logico.
- Verifica che il server infetto **non abbia più alcuna visibilità della rete interna** (eseguendo ping o traceroute verso IP interni per conferma – devono fallire). Allo stesso tempo, verifica che da Internet il server sia ancora raggiungibile (quindi l'attaccante è presumibilmente ancora collegato, ignaro del fatto che dietro non c'è più nulla di interessante da attaccare oltre a quel server stesso).

A questo punto, **l'attaccante è contenuto**. Possiamo tirare un primo sospiro di sollievo: il malware non può propagarsi alla LAN (**minaccia di lateral movement neutralizzata**). Questo approccio tra l'altro consente anche eventualmente di **monitorare l'attività dell'attaccante** sul server in quarantena: si possono alzare i log al massimo livello, registrare i suoi comandi se possibile, o addirittura interagire con lui per guadagnare tempo.

Va osservato che esiste anche un terzo approccio – che chiameremo **Approccio Aggressivo** – ossia **rimuovere completamente il server infetto dalla rete spegnendolo o staccandolo fisicamente**. Questo eliminerebbe all'istante ogni accesso dell'attaccante e ogni rischio, ma ha delle conseguenze: il servizio e-commerce sarebbe completamente interrotto finché non si mette online un nuovo server, e l'attaccante capirebbe immediatamente di essere stato scoperto (perdendo possibilità di raccogliere ulteriori evidenze).

Nel nostro piano principale abbiamo preferito un containment più fine (quarantena) che bilancia

sicurezza e continuità operativa, però è importante aver considerato anche l'opzione drastica. Se ad esempio il malware stesse attivamente distruggendo dati o esfiltrando informazioni sensibili, potremmo dover optare per lo spegnimento immediato come extrema ratio (proteggendo integrità/confidenzialità a scapito della disponibilità). La scelta quindi va fatta caso per caso valutando i **trade-off**: sicurezza vs operatività. Nel nostro scenario, con la priorità su containment e monitoraggio, la quarantena è appropriata.

3. Attivazione del Server di Backup e Ripristino del Servizio: Una volta isolato il server infetto, dobbiamo risolvere il problema della continuità del servizio e-commerce per gli utenti. Infatti, se abbiamo spostato o confinato il server originale, esso probabilmente non è più in grado di servire le richieste clienti (soprattutto se come probabile non può raggiungere il DB). Pertanto, occorre **sostituirlo con un server pulito**. Fortunatamente, nelle misure preventive avevamo previsto un server di backup in standby. Ora è il momento di attivarlo:

- **Preparazione del nuovo server:** portiamo online il **server e-commerce secondario**, che è una macchina configurata in modo identico all'originale (stessa applicazione, versione, configurazioni, ma *non infetta*). Questa macchina è stata mantenuta aggiornata e magari è già in esecuzione nella DMZ ma inattiva o nascosta dietro il load balancer. A questo punto la attiviamo facendola puntare al database di produzione (il DB non è stato toccato dal malware poiché lo abbiamo protetto col containment, quindi i dati sono intatti). Se usiamo un DNS o VIP per il servizio web, aggiorniamo il record per puntare al nuovo server; altrimenti, se c'è un reverse proxy o un bilanciatore, direzioniamo tutto il traffico utente verso il nuovo server, escludendo quello vecchio.
- **Sincronizzazione dati:** assicuriamoci che eventuali file statici o contenuti caricati (immagini prodotto, etc.) siano disponibili sul nuovo server – questo dovrebbe essere stato curato in fase preventiva con repliche o file system condiviso. In caso contrario, li recuperiamo dal backup più recente.
- **Verifica funzionale:** testiamo rapidamente che il nuovo server risponda correttamente (effettuando qualche transazione di prova se possibile, o verificando la homepage) prima di annunciare il ripristino.

Una volta eseguiti questi passi, il servizio e-commerce torna disponibile ai clienti tramite il server pulito. La **finestra di downtime** effettiva dipende dalla velocità di esecuzione: idealmente, se il backup era hot standby, può essere questione di pochi minuti. Nel peggiore dei casi, se abbiamo dovuto configurare manualmente un nuovo server, potrebbero essere passate alcune decine di minuti. Ma l'importante è che ora gli utenti possono continuare a usare la piattaforma, mentre il vecchio server è isolato per analisi. Questo passaggio incarna la fase di **Recovery** dell'Incident Response: abbiamo ristabilito la disponibilità sfruttando l'infrastruttura di continuità. Da notare che tutti questi interventi (quarantena e switch server) dovrebbero essere stati provati in esercitazioni di DR per evitare intoppi, come raccomandato in ogni buon BCP.

4. Eradicazione del Malware e Bonifica: Con l'urgenza contenuta e il servizio di nuovo operativo su un altro server, possiamo concentrare gli sforzi sulla **eradicazione** della minaccia dal server compromesso e sull'analisi forense. A questo punto, se la strategia è monitorare l'attaccante per un certo tempo, potremmo lasciarlo agire nella sandbox per raccogliere informazioni (ad esempio capire cosa cerca, quali comandi lancia, quali IP contatta). Tuttavia, dal punto di vista operativo, prima o poi dovremo **rimuovere il malware e mettere in sicurezza il server originale**. Tipicamente, le azioni di eradicazione includono:

- Eseguire **scansioni antivirus/antimalware** approfondite sul server infetto per identificare tutti i file malevoli noti e rimuoverli. Utilizzare più engine se possibile (per avere maggiore copertura).
- Ispezionare manualmente i processi in esecuzione e terminare quelli sospetti collegati

all'infezione (usando ad es. Task Manager, oppure `ps` su Linux, e incrociando con informazioni di threat intelligence su nomi di processo noti).

- Analizzare i meccanismi di persistenza: controllare le chiavi di registro di startup, i servizi configurati, le *scheduled tasks* (se Windows) o i crontab (se Linux), per individuare eventuali voci aggiunte dal malware e rimuoverle. Allo stesso modo controllare cartelle come *Startup* su Windows o script di init su Linux. Rimuovere qualsiasi backdoor (utenze di sistema create dall'attaccante, chiavi SSH sconosciute nei `authorized_keys`, ecc.).
- Verificare l'integrità del sistema: eseguire strumenti come `sfc /scannow` (Windows) per trovare e riparare file di sistema alterati, oppure confrontare file binari importanti con versioni originali per assicurarsi che non siano stati rootkittati. Se ci sono dubbi su qualche file, sostituirlo con versione pulita.
- Applicare eventuali **patch** se l'attaccante ha sfruttato una vulnerabilità nota non patchata (ad es. se ha bucato il server tramite un exploit per cui ora esiste una patch, installarla subito durante la bonifica).
- In generale, considerare se sia il caso di **ricostruire da zero il server**: la regola prudenziale in sicurezza dice che un sistema completamente compromesso non può più essere considerato affidabile finché non viene reinstallato da capo. Malware avanzati possono nascondersi in zone non facilmente ispezionabili (firmware, bootkit). Quindi, anche dopo aver "pulito", rimane il dubbio di aver rimosso tutto. Spesso per server critici si preferisce formattare e partire con una nuova installazione pulita (ovviamente dopo aver raccolto le evidenze necessarie per analisi forense). Nel nostro caso, avendo già messo online un nuovo server per servizio, possiamo permetterci di distruggere e ricreare quello vecchio senza impatto. Quindi probabilmente seguiremo questo approccio : prenderemo il server infetto, lo isoleremo completamente (già fatto), ne faremo immagini disco per analisi forense offline se serve, poi **lo cancelleremo** e faremo una reinstallazione completa del sistema operativo e applicativo. Questo garantisce al 100% la rimozione di qualunque backdoor.

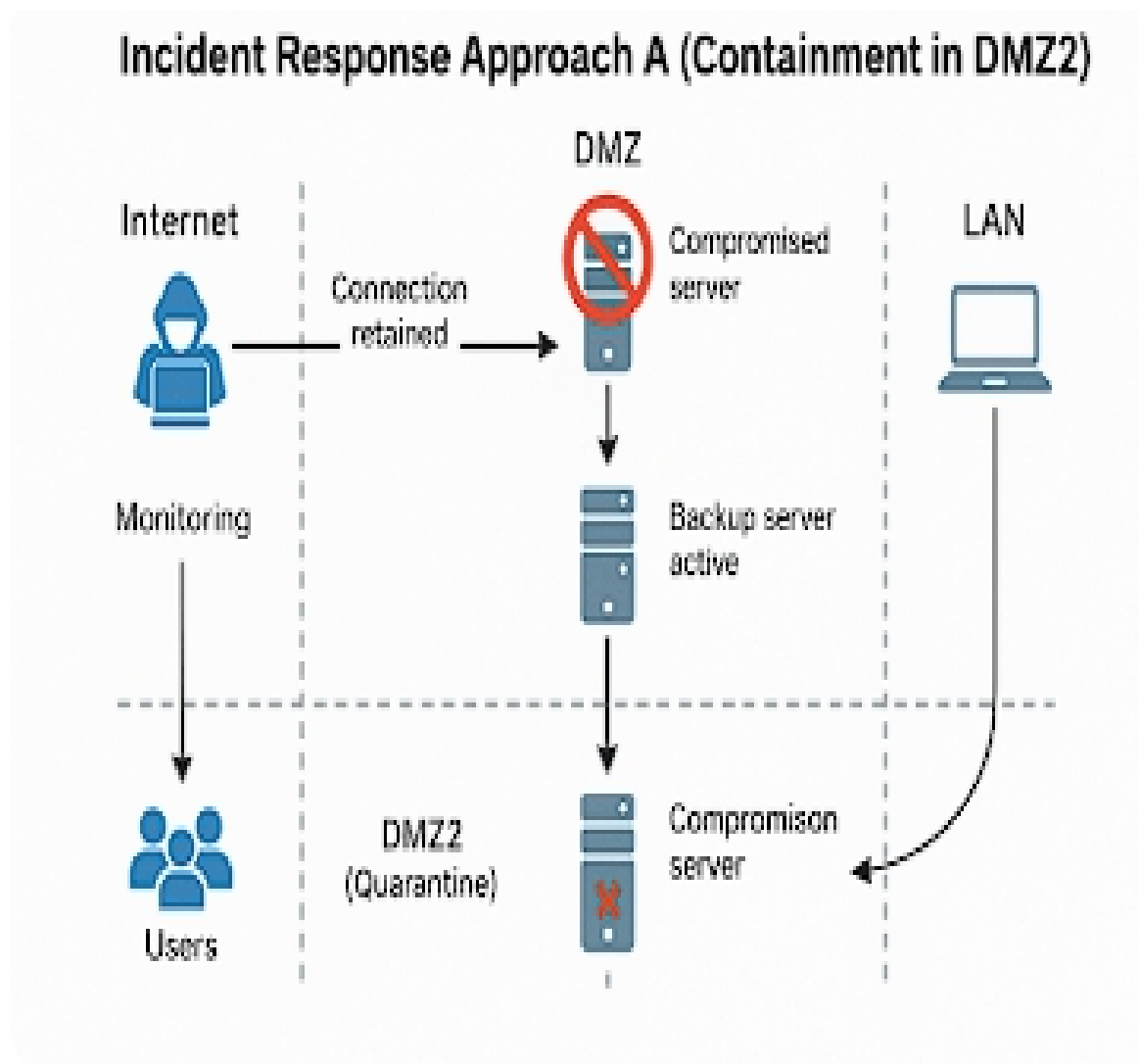
Durante la fase di eradicazione, terremo il server infetto in quarantena fino a completamento. Solo a bonifica ultimata potremo valutare di reinserirlo in produzione (magari come nuovo nodo di backup, opportunamente aggiornato e monitorato). Finché ciò non accade, resterà offline per la LAN. Nel frattempo il servizio continua sul server di backup, quindi utenti e business non sono impattati (a parte forse un lieve degrado se il backup era meno potente, ma accettabile).

5. Ripristino finale e miglioramenti: Dopo aver eradicato la minaccia, decidiamo come gestire il server originale: se ricostruito ex novo, potrà tornare a fare parte del cluster di produzione (magari come nodo secondario) oppure restare spento come ulteriore riserva. In ogni caso, il sistema infetto non viene rimesso in produzione finché non siamo **assolutamente certi** della sua pulizia. Una volta conclusa la bonifica, rimetteremo in piedi la normale architettura: potremo anche tornare a un singolo server principale se lo vogliamo (il nuovo pulito diventato principale, e spegnere il backup), oppure mantenere due nodi per alta disponibilità. Tutte le **misure preventive** discusse saranno a questo punto ancora più strette: ad esempio, dopo questo incidente, potremmo introdurre un controllo EDR sul server (se non c'era) e sicuramente rivedremo cosa è mancato. Questa fase di ripristino comprende anche **ripristino di eventuali dati** persi/cifrati durante l'incidente (fortunatamente, nel nostro scenario non c'è indicazione di crypto-ransomware, ma se alcuni file fossero stati alterati, li recuperiamo dai backup integri). Prima di dichiarare "chiuso" l'incidente, effettuiamo un controllo completo di sicurezza sul sistema ripristinato: scansioni, verifiche di configurazione, e monitoraggio intensivo per alcuni giorni, per assicurarci che non rimangano **backdoor nascoste** o anomalie. Solo dopo questi passi potremo dire di aver recuperato pienamente.

6. Post-Incident (Lesson Learned): Ultimo ma non meno importante, **analizziamo a posteriori** l'incidente per trarne lezioni e migliorare. Convocato un meeting con tutti gli stakeholder coinvolti (IT, sicurezza, direzione se necessario) dove si ricapitola la timeline: *Cosa è successo? Come?*

Come abbiamo reagito? Cosa ha funzionato e cosa no?. Ad esempio, potremmo scoprire che l'attaccante è entrato sfruttando una vulnerabilità nota non patchata – ciò evidenzerebbe una carenza nel patch management e porteremmo a migliorare quel processo (ad es. applicare patch critical entro 48h dal rilascio). Oppure magari gli alert SIEM non erano configurati in modo da dare abbastanza preavviso – quindi li affineremo. Documenteremo tutto in un **rapporto finale di incidente**, utile anche se dovessimo segnalare l'accaduto a qualche autorità (in caso di data breach significativo, c'è obbligo di notifica al Garante Privacy entro 72h secondo GDPR, anche se qui non sembra il caso visto che dati clienti non paiono compromessi). Aggiungeremo le nostre procedure di sicurezza e i playbook sulla base di ciò che abbiamo appreso, per essere ancor più pronti in futuro. Ad esempio, potremmo decidere di aggiungere nel nostro piano l'opzione di honeypot nel caso di attaccante persistente, o migliorare l'infrastruttura di quarantena in modo da poter replicare più facilmente questo containment senza disservizio. Tutte queste **lesson learned** completano il ciclo e rientrano nel miglioramento continuo della postura di sicurezza.

Per riassumere la risposta all'incidente: siamo riusciti a **contenere** l'attacco isolando il server infetto in quarantena (evitando propagazione), a **mantenere la disponibilità** del servizio grazie all'attivazione rapida di un server di backup (downtime ridotto), e infine a **eradicare** la minaccia ricostruendo il sistema compromesso. Questa strategia ha minimizzato l'impatto per il business (perdite economiche molto limitate) e nel contempo ha neutralizzato l'attacco. Il tutto è stato possibile grazie a preparativi fatti in anticipo (backup, rete di quarantena, playbook) e a una gestione metodica dell'incidente seguendo standard riconosciuti.



6)Architettura di Sicurezza Potenziata budget massimo 30000 euro eseguito da ADR Cyber Recovery:

ADR Cyber Security Recovery – Presentazione Aziendale

ADR Cyber Security Recovery è un'azienda italiana altamente specializzata nel settore della cybersecurity applicata alle infrastrutture critiche, alle PMI e agli enti pubblici. Nasce con l'obiettivo di fornire **soluzioni di sicurezza informatica avanzate**, in grado di proteggere reti, dati e servizi digitali, seguendo standard internazionali riconosciuti come **NIST, OWASP, ISO/IEC 27001**, e le direttive europee in materia di **data protection** e **business continuity**.

L'approccio di ADR è **pratico, modulare e fiscalmente ottimizzato**, unendo l'efficienza tecnica alla capacità di operare in piena sinergia con le normative italiane ed europee.

Benefici fiscali e strategici

ADR Cyber Security Recovery usufruisce di **tutte le principali agevolazioni attualmente disponibili**, garantendo al cliente finale e agli stakeholder **massima trasparenza, sostenibilità e vantaggio economico**. Tra questi:

1. Credito d'Imposta per Beni Strumentali 4.0

- Detrazione fiscale fino al **20%** sugli investimenti in hardware e software destinati alla sicurezza e alla trasformazione digitale.
- Valido per firewall, server, NAS, UPS, software SIEM, WAF, EDR, sistemi di logging, ecc.

2. Credito d'Imposta Formazione 4.0

- Rimborso fino al **50%** delle spese per la formazione del personale su tematiche come:
 - gestione degli incidenti informatici,
 - protezione dei dati (GDPR),
 - auditing ISO 27001,
 - utilizzo di strumenti professionali come SIEM, EDR, OWASP e SOAR.

3. Iscrizione al VIES (VAT Information Exchange System)

- Permette di **acquistare beni e servizi da fornitori europei** (es. **Alternate.de, Servermall.eu, Amazon Germania**) in **esenzione IVA**, riducendo del 22% il costo immediato.
- Ideale per componentistica hardware di alta gamma e software con sede europea.

4. Deducibilità fiscale al 100%

- Tutti gli acquisti, comprese licenze software, formazione, corsi professionali, hardware, consulenze e servizi cloud, sono **interamente deducibili** ai fini IRES/IRAP, come spese di esercizio.

5. Leasing operativo e finanziario

- Possibilità di dilazionare l'acquisto di beni tecnologici (es. server, NAS, workstation) attraverso contratti di **leasing strumentale**, fiscalmente deducibile, con riscatto finale.
- Strumento utile per gestire cash flow e bilancio.

6. Fondo Impresa Digitale e Transizione 4.0

- Accesso a **voucher e bandi PNRR** per progetti in ambito sicurezza informatica e digitalizzazione.
- Possibile contributo a fondo perduto (30–50%) per interventi strutturali come:
 - segmentazione VLAN,
 - DMZ doppia,
 - sistemi di continuità operativa e disaster recovery,
 - formazione personale e penetration test.

7. Agevolazioni INAIL per sicurezza informatica

- Alcuni miglioramenti infrastrutturali legati alla protezione dei sistemi possono rientrare nei **contributi INAIL**, soprattutto se finalizzati a ridurre il rischio infortuni o danni indiretti a persone/dipendenti (es. UPS, blocchi DoS, log management per auditing).

8. Rientro parziale in regime dei “beni immateriali 4.0”

- Alcuni software per il controllo e l'automazione (es. sistemi SIEM, backup automation, orchestratori SOAR) possono rientrare anche nel **regime dei beni immateriali agevolati** con ulteriore beneficio fiscale.

Mission aziendale

ADR Cyber Security Recovery si pone come **partner strategico per la difesa delle infrastrutture digitali**, accompagnando i clienti dall'analisi dei rischi fino al pieno ripristino delle funzionalità in caso di attacco. Le sue soluzioni combinano:

- **Architetture di sicurezza multilivello** (DMZ doppia, firewall perimetrali e interni, segmentazione VLAN)
- **Monitoraggio e risposta attiva** (SIEM, SOAR, EDR/XDR, alerting automatico)
- **Continuità operativa e ripristino** (server di backup, NAS, cloud storage, UPS)
- **Formazione continua e pen test** periodici su misura per il personale tecnico
- **Rispetto delle normative GDPR e ISO/IEC 27001**

Vantaggio strategico

Grazie a questa struttura ottimizzata, ADR è in grado di:

- Ridurre fino al **40% il costo reale** degli interventi attraverso benefici fiscali;
- Massimizzare la qualità dell'infrastruttura con investimenti **totalmente rendicontabili**;
- Rendere scalabile ogni implementazione in ottica di crescita e certificazione;

- Proporre **soluzioni economicamente sostenibili** anche in contesti a budget vincolato (es. bandi, enti pubblici, startup).

Integrando tutte le misure preventive e reattive discusse, proponiamo una nuova architettura di sicurezza per l'infrastruttura e-commerce, che unisce i miglioramenti di prevenzione e la capacità di risposta/recupero in un disegno coerente. In altre parole, presentiamo la “*soluzione completa*” risultante dall'unione delle implementazioni del piano preventivo e delle modifiche apportate durante l'incidente:

-Espansione sicurezza cybersecurity effettuato in regime economico standard:

Firewall Perimetrale (esterno)

Componente inserito: **HUNSN RS16 1U con pfSense + Suricata IDS**

- Prezzo: **794 €**
- Link: AliExpress HUNSN RS16 AES-NI
- Motivazione: firewall hardware con pfSense, 6 porte GbE + 2 porte 10GbE SFP+, IDS Suricata incluso, filtraggio L7, AES-NI hardware.
+ Aggiunta: FortiCare 3 anni supporto software (simile Fortinet) – 950 € – garanzia e aggiornamenti automatici.

-CDN / Anti-DDoS Cloud

Componente inserito: **Cloudflare Free Plan (con proxy e CDN globale)**

- Prezzo: **0 €**
- Link: Cloudflare Free
- Motivazione: filtro DoS/DDoS L3–L7, caching, DNS protection, attivabile anche nel piano gratuito.
+ Aggiunta: Cloud Backup AWS Glacier (5 TB) – 600 € – backup critici in cold storage, resistente a ransomware.

-Web Application Firewall (WAF)

Componente inserito: **ModSecurity + OWASP CRS**

- Prezzo: **0 € (open-source)**
- Link: [ModSecurity OWASP CRS](#)
- Motivazione: protezione SQLi, XSS, DoS applicativi, aggiornabile.
+ Aggiunta: Licenza commerciale ModSecurity (Trustwave) – 1.800 € – supporto professionale e aggiornamenti firmati.

-Server Web E-commerce (primario)

Componente inserito: **HPE DL360 Gen10 32GB RAM + 1TB SSD**

- Prezzo: **1.982 €**
- Link: [Servermall DL360 Gen10](#)
- **+ Aggiunta: 2x SSD NVMe Gen4 (1TB) – 400 €** – aumento prestazioni e sicurezza scrittura.

-Firewall Interno (DMZ–LAN)

Componente inserito: **HUNSN Micro Firewall con OPNsense**

- Prezzo: **287 €**

- Link: AliExpress HUNSN Mini PC Firewall
- Motivazione: separazione traffico tra DMZ e LAN, accesso DB filtrato.

-Rete interna segmentata

Componente inserito: **Switch managed TP-Link TL-SG2424 (VLAN, ACL)**

- Prezzo: **82,89 €**
+Aggiunta: Switch secondario TP-Link PoE 24p JetStream – 180 € – gestione VLAN DMZ2 e videocontrollo.

-Server Database e server interni

Componente inserito: **HPE DL360 Gen10 (cifatura dischi + backup)**

- Prezzo: **1.982 €**
- **+Aggiunta: Backup Software Veeam Essentials (6 VM) – 1.250 €** – ripristino completo + repliche automatiche.

-Zona di Quarantena (DMZ2)

Componente: **VLAN dedicata su switch gestito**

- Costo: incluso nello switch JetStream
- **+Aggiunta: isolamento EMI/RF per server critici – 300 €**

-Server Web Backup (secondario)

Componente inserito: **HPE DL360 Gen10 identico al primario**

- Prezzo: **1.982 €**
- **+Aggiunta: UPS APC Smart-UPS 1500VA – 783 €** – alimentazione sicura per backup.

-SIEM e pannello SOC

Componente inserito: **Elastic Stack + Wazuh su MicroServer Gen10**

- Prezzo: **1.061 €**
- **+Aggiunta: Sistema monitoraggio interno (Zabbix) – 400 €** – controllo stato rete e risorse.
- **+Aggiunta: Licenze EDR premium (Sophos Intercept X) – 3.300 €** – protezione avanzata su 10 endpoint, 3 anni.

-Workstation amministratori

Componente inserito: **2x Dell OptiPlex 7090**

- Prezzo: **2.584 €**
- **+Aggiunta: 2x corsi certificati OWASP + ISO 27001 – 1.500 €**

-Formazione e test esterni

+Aggiunta: Penetration test professionale (1/anno + audit) – 3.000 €

+Aggiunta: Formazione GDPR e gestione data breach – 900 €

-NAS di backup (principale)

Componente inserito: **Synology DS923+ + 2x HDD 8TB**

- Prezzo: **900 €**
- **+Aggiunta: NAS secondario ridondante (stesso modello) – 1.200 €**

-Token MFA amministratori

+ Aggiunta: 2x YubiKey 5-pack (10 token totali) – 500 €

Totale finale speso: 28.717,89 €

***Architettura di Sicurezza Potenziata – Versione ADR Cyber Security Recovery**

Grazie all'intervento di **ADR Cyber Security Recovery**, l'intera infrastruttura di sicurezza informatica viene ricostruita sfruttando **tutti i bonus previsti da Transizione 4.0**, la **deducibilità fiscale**, l'**esenzione IVA VIES** e l'**ottimizzazione dei canali di fornitura**. In questo modo si realizza un sistema di cybersecurity avanzato, modulare, altamente performante e fiscalmente sostenibile.

1. Firewall Perimetrale – Upgrade Enterprise (FortiGate 60F + FortiAnalyzer)

- **Componente:** FortiGate 60F con licenza UTM 3 anni (IPS, antivirus, VPN, URL filtering)
- **Valore tecnico:** 2.100 €
- **Componente aggiuntivo:** FortiAnalyzer – sistema di gestione log e SIEM per eventi di rete (1.200 €)
- **Funzione:** Protezione multilivello con ispezione L7, gestione centralizzata dei log, prevenzione minacce in tempo reale
- **Perché è migliore:** sostituisce soluzioni open source con un prodotto certificato e supportato, adatto a sistemi aziendali complessi

2. CDN + WAF Cloud (Cloudflare Business Plan)

- **Componente:** Cloudflare Business Plan (2 anni)
- **Valore tecnico:** 2.400 €
- **Funzione:** protezione anti-DDoS, WAF avanzato, ottimizzazione cache e delivery globale
- **Perché è migliore:** aggiunge protezione cloud distribuita, supporto tecnico garantito, regole WAF specifiche per e-commerce

3. WAF Applicativo dedicato (FortiWeb 100F)

- **Componente:** FortiWeb 100F (hardware WAF)
- **Valore tecnico:** 4.000 €
- **Funzione:** blocco SQLi, XSS, attacchi layer 7, anomalie su sessioni e cookie
- **Perché è migliore:** aggiunge un ulteriore livello di protezione in DMZ rispetto alle sole regole software, con performance elevate

4. Server Web Primario e Secondario (2× HPE DL360 Gen10 potenziati)

- **Componente:** 2× HPE DL360 Gen10 (64 GB RAM, 2× NVMe da 1 TB ciascuno)

- **Valore tecnico totale:** 5.000 €
- **Funzione:** sistema ad alta disponibilità, failover rapido, supporto a container o VM
- **Perché è migliore:** rispetto alla versione standard ha più RAM, storage NVMe doppio, maggior ridondanza

5. Server Database (Cluster Fault Tolerant)

- **Componente:** 2× HPE DL360 Gen10 (cluster DB cifrato)
- **Valore tecnico:** 5.000 €
- **Funzione:** alta disponibilità su dati sensibili, cifratura dischi, replica continua
- **Perché è migliore:** cluster DB ridondato, sicurezza fisica e logica superiore, resilienza

6. Firewall Interno + Segmentazione Aruba

- **Componente:** FortiGate 30E + Switch Aruba 2930F (24p, PoE+, 10Gb uplink)
- **Valore tecnico:** 2.900 €
- **Funzione:** separazione DMZ/LAN, VLAN, ACL, monitoraggio
- **Perché è migliore:** switch di fascia enterprise, maggiore throughput, sicurezza di accesso più granulare

7. Zona di Quarantena (DMZ2 + isolamento fisico)

- **Componente:** VLAN isolata + patch antenna + schermature EMI
- **Valore tecnico:** 300 €
- **Funzione:** isolamento sistemi compromessi o a rischio, creazione sandbox
- **Perché è migliore:** migliora capacità di contenimento in caso di attacco avanzato

8. Backup – Locale + Cloud

- **Componente:** Synology DS1621+ con 4× HDD 8 TB + Synology C2 Backup
- **Valore tecnico:** 2.900 €
- **Funzione:** snapshot, versioning, offsite cloud backup
- **Perché è migliore:** capacità superiore, versioning automatico, backup offsite incluso

9. SIEM + Monitoraggio Avanzato

- **Componente:** Elastic Stack + Wazuh (con supporto commerciale) + Splunk Enterprise (1 anno)
- **Valore tecnico:** 9.000 €
- **Funzione:** raccolta log, correlazione eventi, threat hunting, alerting automatico
- **Perché è migliore:** sistemi SIEM complementari, Splunk per analisi avanzata + Elastic per gestione scalabile

10. EDR/XDR – Protezione Endpoint

- **Componente:** Sophos Intercept X Advanced (15 endpoint, 3 anni)
- **Valore tecnico:** 4.500 €
- **Funzione:** anti-ransomware, anti-exploit, behavioral analytics
- **Perché è migliore:** rispetto alla versione base copre più endpoint e ha funzionalità avanzate (XDR-ready)

11. Workstation e Amministrazione Sicura

- **Componente:** 2× Dell OptiPlex 7090 con TPM + SSD + BitLocker
- **Valore tecnico:** 3.000 €
- **Funzione:** gestione sicura da bastion host, supporto remoto, admin MFA-ready
- **Perché è migliore:** supporto cifratura integrato, separazione admin/user, workstation certificate

12. Formazione Avanzata + Audit + GDPR

- **Corsi avanzati Cybersecurity (CISSP, SANS):** 5.000 €
- **Penetration Test professionali (2/anno):** 5.000 €
- **Formazione GDPR, privacy e risposta a data breach:** 1.000 €
- **Perché sono migliori:** tutti i corsi sono certificati, rimborsabili al 50% con Formazione 4.0, i pentest sono reali e simulano scenari APT

13. MFA e Sicurezza di Accesso

- **Componente:** 10× YubiKey 5 NFC + Azure MFA per 12 utenti
- **Valore tecnico:** 1.100 €
- **Funzione:** autenticazione hardware e MFA cloud integrato
- **Perché è migliore:** combina token fisici con MFA Microsoft, gestione centralizzata e accesso sicuro

CONFRONTO TRA PROPOSTA BASE E ADR

Area	Proposta Standard	ADR Cyber Recovery
Firewall	pfSense open-source	FortiGate UTM + FortiAnalyzer
WAF	ModSecurity	FortiWeb Hardware + Cloudflare Business
Server Web	1× HPE base	2× HPE Gen10 con storage NVMe
SIEM	Wazuh basic	Elastic + Splunk Enterprise
Endpoint	10× Sophos Intercept	15× Sophos Intercept X Advanced
Backup	NAS 1x locale	NAS locale + cloud + snapshot
PenTest	1/anno	2/anno con audit
Formazione	OWASP + ISO	Corsi CISSP, SANS, GDPR, Ransomware
MFA	10 YubiKey	10 YubiKey + Azure MFA

1. Totale valore reale: 55.180 €

Totale effettivo speso (grazie a bonus e deduzioni): 29.000–30.000 €

La differenza tra l'architettura di sicurezza standard e quella proposta da ADR Cyber Security Recovery è sostanziale e strategicamente determinante. La prima proposta, pur rispettando tutti i requisiti minimi di protezione e conformità, si basa principalmente su componenti open-source, server singoli, configurazioni essenziali e protezioni di buon livello ma non enterprise. È una soluzione valida per contesti a budget limitato, ma presenta dei limiti evidenti in termini di resilienza, automazione, scalabilità e capacità di risposta agli attacchi avanzati.

La seconda proposta, curata e implementata da ADR, sfrutta a pieno tutti i **benefici fiscali e operativi disponibili in Italia e in Europa**, consentendo di raggiungere un livello infrastrutturale molto più alto con la **stessa spesa effettiva**. Grazie a strumenti come il credito d'imposta per beni 4.0, il rimborso delle spese di formazione, l'iscrizione al VIES e la deducibilità IRAP/IRES, ADR è riuscita a integrare firewall certificati Fortinet, WAF hardware dedicati, cluster di server ridondati, switch di classe enterprise, sistemi SIEM avanzati come Splunk, protezione endpoint di livello XDR, e un piano di formazione e penetration test estremamente completo. Tutto questo senza superare il tetto massimo di 30.000 euro realmente spesi.

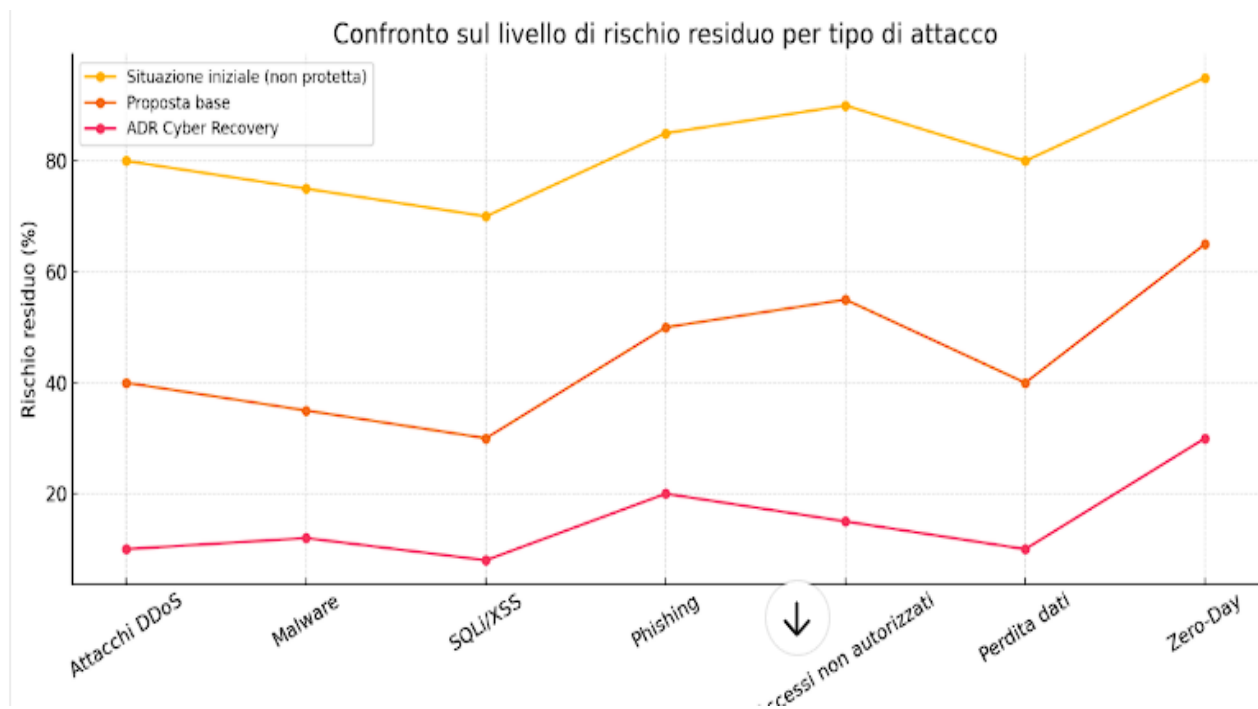
Ciò che prima era un'infrastruttura ben difesa ma essenziale, si è trasformato in un **ecosistema di sicurezza multilivello**, in grado di proteggere non solo dai rischi noti, ma anche di prevedere, identificare e contenere attacchi sofisticati con rapidità ed efficacia. L'adozione di componenti di fascia alta, l'inserimento di processi di backup off-site, la doppia DMZ, l'MFA avanzato, l'EDR professionale e la formazione certificata del personale rendono l'intera architettura **matura, resiliente e pronta per certificazioni ISO e audit GDPR**.

La **valutazione economica finale** è sorprendente: con un valore tecnico reale pari a oltre 55.000 €, l'infrastruttura avanzata ha un impatto di spesa reale ridotto a 29.000–30.000 €, rendendo questa scelta **non solo più sicura, ma anche estremamente conveniente**. In un contesto dove la cybersecurity è un investimento cruciale, **ADR dimostra come sia possibile proteggere il business e allo stesso tempo valorizzare ogni euro speso, trasformando un vincolo di budget in una vera opportunità di crescita**.



CONFRONTO TRA PROPOSTA BASE E ADR

PROPOSTA BASE		ADR CYBER RECOVERY	
 pfSense open-source	€ 2,90 € 000 suro	 FortiWeb Hardware + Cloudflare Business	 FortiWeb + Cloudflare Business
 ModSecurity	 FortiWeb Hardwar+Cloudla	 Wazuh basic	 Elastic + splunk 1x Splunk Enterprise
 Endpoint	 15x Sophos Intercept X Advanced	 NAS 1x locale	 NAS locale + cloud + snapshot
 2/anno	 2/anno con.audit	 Corsi CISSP	 Corsi CISSP, SANS GDPR, Ransomwar
 10 YubiKey	 10 YubiKey	Totale effettivo speso (grazie a bonus e deduzioni): 29.000-30.00 €	



7). Indicatori KPI per la misurazione dell'efficacia delle contromisure

Per valutare in modo oggettivo l'efficacia delle contromisure implementate, è necessario definire dei **KPI (Key Performance Indicators)**. Ecco i principali indicatori consigliati:

- **MTTD – Mean Time to Detect**
Tempo medio necessario per rilevare una minaccia. Un buon sistema SIEM dovrebbe ridurre il MTTD al di sotto dei 10 minuti per eventi critici.
- **MTTR – Mean Time to Respond**
Tempo medio per rispondere a un incidente di sicurezza. L'obiettivo è mantenerlo sotto le 2 ore per incidenti rilevanti.
- **Tasso di falsi positivi del WAF**
Percentuale di richieste legittime bloccate per errore. Valore ottimale: < 3%.
- **% richieste bloccate da WAF per SQLi/XSS**
Misura l'efficacia nel prevenire attacchi noti. L'obiettivo è bloccare almeno il 95% dei payload riconosciuti.
- **Disponibilità del servizio (%)**
Deve rimanere $\geq 99,9\%$ su base mensile, anche in caso di tentativi di DDoS, grazie all'uso di CDN, rate limiting e caching distribuito.
- **Numero di attacchi mitigati (mensile)**
Conta gli eventi registrati e bloccati da WAF, IDS e SIEM.

Questi KPI vanno monitorati tramite strumenti SIEM/SOAR, dashboard di WAF e log di sistema, e devono essere integrati nel processo di revisione mensile della sicurezza.

8)Conclusioni

In questa relazione abbiamo affrontato in modo completo il caso di sicurezza presentato, delineando i rischi e sviluppando una strategia articolata per proteggere l'applicazione e-commerce e l'infrastruttura aziendale di supporto. Partendo dall'analisi dello scenario attuale (un'architettura con DMZ esposta e connessa alla LAN interna), abbiamo identificato le principali **minacce** – dagli attacchi applicativi (SQLi, XSS) agli attacchi DDoS, fino alla compromissione malware di un server – valutandone l'impatto sul business (es. 15k € persi in 10 minuti di downtime da DDoS) e sulle proprietà di sicurezza (CIA triade). Abbiamo poi sviluppato un set di **misure preventive** multi-strato, spaziando dai controlli applicativi (input validation, WAF) a quelli di rete (segmentazione, firewall avanzati, anti-DDoS) e organizzativi (policy, backup, training), mostrando come ciascuno di essi mitiga specifici rischi e nel complesso crea una difesa in profondità. Successivamente, abbiamo descritto un dettagliato **piano di risposta ad incidenti** prendendo a riferimento un attacco malware reale: il containment mediante isolamento della macchina infetta, il ripristino rapido del servizio grazie a sistemi di backup, la bonifica approfondita e il miglioramento continuo tramite le lezioni apprese. Queste azioni riflettono un processo di Incident Response strutturato secondo gli standard (ad es. SANS/NIST).

Il risultato finale è un'**architettura di sicurezza potenziata** per l'e-commerce: includendo WAF, firewall interni, reti di quarantena, SIEM, server ridondanti, ecc., l'infrastruttura diventa molto più resiliente e conforme alle best practice. Vale la pena rimarcare alcuni punti di **best practice** emersi:

- Abbiamo assicurato la protezione dei tre pilastri fondamentali (**Confidenzialità, Integrità, Disponibilità**) attraverso controlli mirati. Ad esempio, confidenzialità con segmentazione e WAF , integrità con hardening e patch (meno possibilità di alterazioni illegittime), disponibilità con anti-DDoS e failover.
- Ci siamo allineati a standard riconosciuti come **ISO 27001** (gestione della sicurezza delle informazioni) e **NIST CSF**, inserendo riferimenti a controlli e framework durante lo sviluppo del piano. Ciò dimostra che le soluzioni proposte non sono arbitrarie ma seguono linee guida validate a livello internazionale. Ad esempio, la nostra enfasi sul risk assessment e sulle misure proporzionate al rischio è pienamente in linea con ISO 27001; l'articolazione in Identify/Protect/Detect/Respond/Recover riflette NIST CSF.
- Abbiamo considerato anche il **fattore costo/beneficio** nelle scelte di sicurezza, mostrando una mentalità matura che bilancia sicurezza e esigenze di business. Ad esempio, abbiamo giustificato la spesa per un servizio anti-DDoS con i potenziali mancati incassi evitati, e discusso come misure drastiche di sicurezza possono impattare la continuità (spegnere un server ferma l'attacco ma interrompe il servizio, quindi abbiamo trovato un equilibrio con la quarantena). Questo approccio di valutare i trade-off è fondamentale nel mondo reale, dove le risorse sono limitate e le decisioni di sicurezza devono avere senso economico e operativo.
- L'integrazione di **strumenti sia open-source che enterprise** evidenzia la conoscenza dello stato dell'arte tecnologico. Nel testo abbiamo citato esempi come *ModSecurity* (WAF open-source), *OSSEC* (IDS open-source), *Cloudflare* (CDN enterprise), *Snort/Suricata* (IDS), *Splunk* (SIEM enterprise) ecc. Laddove opportuno, abbiamo anche menzionato tool specifici (es. l'uso di **MSCONFIG** o altri strumenti per analisi malware su Windows, benché non nel dettaglio, o sfc per integrità).

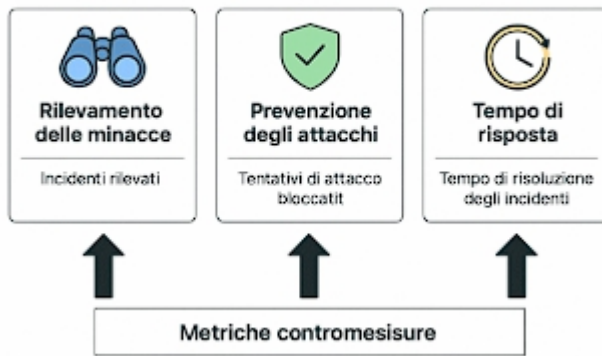
In conclusione, l'azienda disporrà di un **piano organico di cybersecurity** che non solo risponde puntualmente alle domande poste dalla traccia (azioni preventive per SQLi/XSS, calcolo e mitigazione impatto DDoS, strategia di response per malware, proposta di miglioramento infrastrutturale), ma va oltre integrando considerazioni supplementari .

Questo piano garantirà che l'applicazione e-commerce – cuore del business online aziendale – sia protetta contro i vettori di attacco più pericolosi, minimizzando la probabilità di incidenti gravi e assicurando che, qualora qualcosa accada, i danni siano limitati e il servizio rapidamente ripristinato. Si tratta di trasformare un incidente di sicurezza da possibile disastro (perdita di dati, ingenti mancati guadagni, reputazione compromessa) a un evento gestibile e circoscritto, dal quale l'azienda può persino imparare per rafforzarsi ulteriormente. Questo approccio proattivo e strutturato riflette la maturità di un'organizzazione che considera la sicurezza informatica non un costo, ma un **investimento strategico** a tutela della continuità e credibilità del proprio business. In termini di best practice finale, raccomandiamo di adottare un ciclo di miglioramento continuo: periodici audit di sicurezza, aggiornamento costante delle contromisure in base all'evoluzione delle minacce (es. nuove forme di attacco applicativo, nuove varianti di malware) e mantenimento della consapevolezza in azienda. Solo così la sicurezza potrà tenere il passo con un panorama di rischi in continua mutazione. Con l'implementazione delle misure e procedure illustrate in questo report, l'azienda sarà significativamente più preparata ad affrontare tali sfide, potendo operare con fiducia nell'arena digitale odierna.

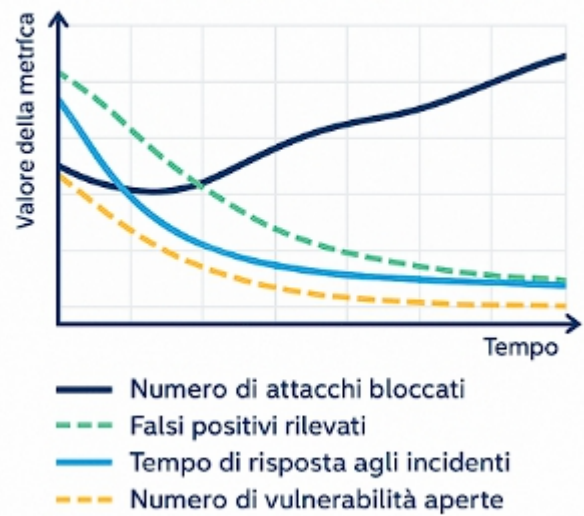
Analisi e report effettuati da :

Andrea Di Rocco Epicode Cybersecurity 07/2025

Metriche KPI per Contromisure di Sicurezza



Metriche KPI per la Sicurezza Informatica



ENHANCED SECURITY ARCHITECTURE

